



Πανεπιστήμιο Πειραιώς
Σχολή Τεχνολογιών Πληροφορικής και Τηλεπικοινωνιών
Τμήμα Ψηφιακών Συστημάτων
Π.Μ.Σ. «Κυβερνοασφάλεια και Τεχνολογίες Τεχνητής Νοημοσύνης»

Διαχείριση Ασφάλειας Πληροφοριών

Ανάλυση μεθοδολογιών και εργαλείων λογισμικού, για τη διοίκηση
κινδύνων/επικινδυνότητας για την ασφάλεια πληροφοριών

Επιβλέποντες Καθηγητές: Κ. Λαμπρινουδάκης – Σ. Γκρίζαλης

Καλαϊτζίδης Ιωάννης

ioannis_kalaitzidis@ssl-unipi.gr

Πειραιάς
22/12/2025

Περίληψη

Η παρούσα εργασία εξετάζει συγκριτικά τις μεθοδολογίες διαχείρισης κινδύνου ISO/IEC 27005:2022 και NIST (SP 800-30 rev.1 και SP 800-39), ενώ παράλληλα αξιολογεί πρακτικά τέσσερα εξειδικευμένα εργαλεία λογισμικού (SimpleRisk, Monarc, Verinice, EAR/PILAR). Μέσω της θεωρητικής ανάλυσης, αναδεικνύονται οι θεμελιώδεις διαφορές μεταξύ της ευέλικτης φιλοσοφίας του ISO και της αυστηρά δομημένης προσέγγισης του NIST. Ταυτόχρονα, η πρακτική δοκιμή των εφαρμογών αποτυπώνει την απόσταση μεταξύ θεωρητικών προτύπων και λειτουργικής πραγματικότητας, προσφέροντας τεκμηριωμένα συμπεράσματα για την επιλογή της βέλτιστης λύσης με βάση την ευχρηστία, το κόστος και τις κανονιστικές απαιτήσεις.

Abstract

This thesis provides a comparative analysis of the ISO/IEC 27005:2022 and NIST (SP 800-30 rev.1 and SP 800-39) risk management methodologies, alongside a practical evaluation of four specialized software tools (SimpleRisk, Monarc, Verinice, EAR/PILAR). Theoretical analysis highlights the fundamental contrast between ISO's flexible framework and NIST's structured approach. Concurrently, the practical assessment reveals the gap between theoretical standards and operational reality, offering evidence-based conclusions to guide the selection of the optimal solution based on usability, cost, and compliance requirements.

Περιεχόμενα

1. Εισαγωγή.....	5
1.1 Αντικείμενο και Σκοπός της Εργασίας.....	5
1.2 Μεθοδολογία και Κριτήρια Αξιολόγησης.....	5
2. Ανάλυση Μεθοδολογίας ISO 27005.....	7
2.1 Ταυτότητα και προέλευση.....	7
2.1.1 Φορέας Έκδοσης και Προέλευση.....	7
2.1.2 Τρέχουσα Έκδοση.....	7
2.1.3 Νομική Φύση.....	8
2.1.4 Γεωγραφική Εμβέλεια.....	8
2.1.5 Κόστος Πρόσβασης.....	9
2.2 Σκοπός και αρχιτεκτονική.....	9
2.2.1 Επίπεδο εστίασης.....	9
2.2.2 Σχέση με άλλα πρότυπα.....	10
2.2.3 Κύκλος Διαχείρισης.....	11
2.3 Μεθοδολογία Αξιολόγησης Κινδύνου.....	12
2.3.1 Προσέγγιση αξιολόγησης.....	12
2.3.2 Ευελιξία μεθοδολογίας.....	14
2.3.3 Τεχνική υπολογισμού ρίσκου.....	14
2.3.4 Κατάλογοι απειλών/ευπαθειών.....	15
2.4 Πόροι και Εφαρμογή.....	15
2.4.1 Πολυπλοκότητα υλοποίησης.....	16
2.4.2 Απαιτούμενοι πόροι (κόστος εφαρμογής).....	16
3. Ανάλυση Μεθοδολογιών NIST (SP 800-30 rev.1 και SP 800-39).....	18
3.1 Εισαγωγή.....	18
3.2 Ταυτότητα και προέλευση.....	18
3.2.1 Φορέας Έκδοσης και Προέλευση.....	18
3.2.2 Τρέχουσα Έκδοση.....	19
3.2.3 Νομική Φύση.....	19

3.2.4 Γεωγραφική Εμβέλεια.....	20
3.2.5 Κόστος Πρόσβασης.....	21
3.3 Σκοπός και αρχιτεκτονική.....	21
3.3.1 Επίπεδο εστίασης.....	21
3.3.2 Σχέση με άλλα πρότυπα.....	22
3.3.3 Κύκλος Διαχείρισης.....	23
3.4 Μεθοδολογία Αξιολόγησης Κινδύνου.....	24
3.4.1 Προσέγγιση αξιολόγησης.....	24
3.4.2 Ευελιξία μεθοδολογίας.....	25
3.4.3 Τεχνική υπολογισμού ρίσκου.....	25
3.4.4 Κατάλογοι απειλών/ευπαθειών.....	26
3.5 Πόροι και Εφαρμογή.....	27
3.5.1 Πολυπλοκότητα υλοποίησης.....	27
3.5.2 Απαιτούμενοι πόροι (κόστος εφαρμογής).....	28
4. Συγκριτική Αξιολόγηση και Συμπεράσματα.....	30
4.1 Συγκεντρωτικός Πίνακας Κριτηρίων.....	30
4.2 Συμπεράσματα Θεωρητικής Σύγκρισης.....	33
5. Παρουσίαση Εργαλείων Λογισμικού.....	35
5.1 Εισαγωγή.....	35
5.2 Εργαλεία.....	37
5.2.1 SimpleRisk.....	37
5.2.1.1 Τεχνική Ταυτότητα και Αδειοδότηση.....	37
5.2.1.2 Λειτουργικότητα Διαχείρισης Κινδύνου.....	39
5.2.1.3 Εμπειρία Χρήστη.....	42
5.2.2 Monarc.....	43
5.2.2.1 Τεχνική Ταυτότητα και Αδειοδότηση.....	43
5.2.2.2 Λειτουργικότητα Διαχείρισης Κινδύνου.....	44
5.2.2.3 Εμπειρία Χρήστη.....	49
5.2.3 Verinice.....	50
5.2.3.1 Τεχνική Ταυτότητα και Αδειοδότηση.....	50
5.2.3.2 Λειτουργικότητα Διαχείρισης Κινδύνου.....	51

5.2.3.3 Εμπειρία Χρήστη.....	54
5.2.4 EAR/PILAR.....	54
5.2.4.1 Τεχνική Ταυτότητα και Αδειοδότηση.....	55
5.2.4.2 Λειτουργικότητα Διαχείρισης Κινδύνου.....	57
5.2.4.3 Εμπειρία Χρήστη.....	60
5.3 Συγκριτική Αξιολόγηση και Συμπεράσματα.....	61
6. Βιβλιογραφία.....	65

1. Εισαγωγή

1.1 Αντικείμενο και Σκοπός της Εργασίας

Το αντικείμενο της παρούσας εργασίας εμπίπτει στο ευρύτερο πεδίο της Διοίκησης Επικινδυνότητας Ασφάλειας Πληροφοριών (Information Security Risk Management- ISRM), μια διαδικασία ζωτικής σημασίας για τη διασφάλιση της ακεραιότητας, της εμπιστευτικότητας και της διαθεσιμότητας των δεδομένων σε σύγχρονους οργανισμούς. Καθώς οι κυβερνοαπειλές εξελίσσονται και το κανονιστικό πλαίσιο γίνεται αυστηρότερο, η επιλογή της κατάλληλης μεθοδολογίας και των υποστηρικτικών εργαλείων λογισμικού καθίσταται κρίσιμη απόφαση στρατηγικής σημασίας.

Σκοπός της εργασίας είναι η θεωρητική συγκριτική αξιολόγηση δύο εκ των πλέον αναγνωρισμένων μεθοδολογιών παγκοσμίως: του διεθνούς προτύπου ISO 27005 και των κατευθυντήριων οδηγιών του Εθνικού Ινστιτούτου Προτύπων και Τεχνολογίας των ΗΠΑ (NIST), συγκεκριμένα των εγγράφων NIST SP 800-30 rev.1 (Guide for Conducting Risk Assessments) και NIST SP 800-39 (Managing Information Security Risk). Η σύγκριση αυτή δεν περιορίζεται σε επιφανειακή παραβολή, αλλά βασίζεται στην ανάπτυξη και εφαρμογή ενός συνόλου συγκεκριμένων κριτηρίων που αφορούν τη δομή, τη μεθοδολογία ανάλυσης, την ευελιξία και τις απαιτήσεις πόρων. Επιπλέον η εργασία στοχεύει στην πρακτική αξιολόγηση τεσσάρων εργαλείων λογισμικού (SimpleRisk, Monarc, Verinice, EAR/PILAR) που υποστηρίζουν τη διαδικασία διοίκησης επικινδυνότητας. Μέσω της εγκατάστασης και δοκιμαστικής λειτουργίας (σε περιβάλλον open source ή trial), θα εξεταστεί ο βαθμός στον οποίο τα εργαλεία αυτά ενσωματώνουν τις θεωρητικές μεθοδολογίες και ανταποκρίνονται στις ανάγκες ενός οργανισμού, βάσει ενός δεύτερου συνόλου τεχνικών και λειτουργικών κριτηρίων.

Συνοπτικά, η παρούσα μελέτη φιλοδοξεί να γεφυρώσει το χάσμα μεταξύ της θεωρητικής προσέγγισης των προτύπων και της πρακτικής εφαρμογής τους μέσω ψηφιακών εργαλείων, παρέχοντας τεκμηριωμένα συμπεράσματα για την επιλογή της βέλτιστης λύσης.

1.2 Μεθοδολογία και Κριτήρια Αξιολόγησης

Για την υλοποίηση της συγκριτικής μελέτης υιοθετήθηκε μια συστηματική μεθοδολογική προσέγγιση που διακρίνεται σε δύο φάσεις, αντίστοιχες με τους στόχους της εργασίας, τη θεωρητική ανάλυση των προτύπων και την πρακτική αξιολόγηση των εργαλείων.

Όσον αφορά το πρώτο και θεωρητικό σκέλος της εργασίας (Σύγκριση ISO 27005 με NIST SP 800-30 rev.1 και NIST SP 800-39), αναπτύχθηκε ένα εξειδικευμένο πλαίσιο αξιολόγησης. Προκειμένου η σύγκριση να είναι δομημένη και αντικειμενική, ορίστηκαν τέσσερις θεμελιώδεις θεματικοί άξονες (κριτήρια), οι οποίοι εφαρμόζονται οριζόντια και στις δύο υπό εξέταση μεθοδολογίες:

1. Ταυτότητα και Προέλευση:

Εξετάζονται τα «διοικητικά» χαρακτηριστικά των εγγράφων, όπως ο φορέας έκδοσης, η νομική τους φύση, η γεωγραφική τους εμβέλεια και το κόστος απόκτησης και χρήσης τους.

2. Σκοπός και Αρχιτεκτονική:

Αναλύεται το εύρος εφαρμογής και η δομική φιλοσοφία κάθε πλαισίου. Ειδικότερα, διερευνάται αν η μεθοδολογία ακολουθεί μια ενιαία προσέγγιση ή αν διαχωρίζεται σε επίπεδα, καθώς και πώς εντάσσεται στον κύκλο ζωής διαχείρισης.

3. Μεθοδολογία Ανάλυσης (Risk Assessment Methodology):

Αξιολογείται ο τεχνικός πυρήνας της διαδικασίας. Συγκρίνονται οι προσεγγίσεις ως προς τον προσανατολισμό, ο βαθμός ευελιξίας που παρέχεται στον οργανισμό, καθώς και οι προτεινόμενες τεχνικές υπολογισμού του ρίσκου.

4. Πόροι και Εφαρμογή:

Εκτιμώνται οι απαιτήσεις για την υλοποίηση του κάθε προτύπου σε επίπεδο ανθρωπίνων πόρων, τεχνογνωσίας και πολυπλοκότητας, καθώς και η αναγκαία γραφειοκρατική υποστήριξη.

2. Ανάλυση Μεθοδολογίας ISO 27005

2.1 Ταυτότητα και προέλευση

2.1.1 Φορέας Έκδοσης και Προέλευση

Το πρότυπο ISO/IEC 27005 εκδίδεται από κοινού από τον Διεθνή Οργανισμό Τυποποίησης (ISO) και τη Διεθνή Ηλεκτροτεχνική Επιτροπή (IEC), οι οποίοι σχηματίζουν το εξειδικευμένο σύστημα για την παγκόσμια τυποποίηση [1]. Οι εθνικοί φορείς που είναι μέλη του ISO ή της IEC συμμετέχουν στην ανάπτυξη των Διεθνών Προτύπων μέσω τεχνικών επιτροπών που ιδρύονται από τον αντίστοιχο οργανισμό για να ασχοληθούν με συγκεκριμένους τομείς τεχνικής δραστηριότητας [2]. Στην περίπτωση της Ελλάδας, ο εθνικός φορέας που αποτελεί πλήρες μέλος και εκπροσωπεί τη χώρα στους οργανισμούς ISO και IEC είναι ο Ελληνικός Οργανισμός Τυποποίησης (ΕΛΟΤ) [5].

Συγκεκριμένα, το παρόν έγγραφο εκπονήθηκε από τη Μικτή Τεχνική Επιτροπή ISO/IEC JTC 1 (Τεχνολογία Πληροφοριών) και ειδικότερα από την Υποεπιτροπή SC 27, η οποία είναι αρμόδια για την ασφάλεια πληροφοριών, την κυβερνοασφάλεια και την προστασία της ιδιωτικότητας [3]. Όσον αφορά την προέλευση της τρέχουσας έκδοσης, αυτή αποτελεί την τέταρτη έκδοση του προτύπου, η οποία ακυρώνει και αντικαθιστά την τρίτη έκδοση (ISO 27005:2018) [4].

2.1.2 Τρέχουσα Έκδοση

Η τρέχουσα διεθνής έκδοση του προτύπου, η οποία αποτελεί αντικείμενο της παρούσας μελέτης, είναι η τέταρτη έκδοση και δημοσιεύθηκε τον Οκτώβριο του 2022 [6]. Σημειώνεται ότι το πρότυπο έχει υιοθετηθεί αυτούσιο στην ελληνική τυποποίηση ως ΕΛΟΤ EN ISO/IEC 27005:2024. Η συγκεκριμένη έκδοση ακυρώνει και αντικαθιστά την τρίτη έκδοση (ISO 27005:2018), η οποία έχει υποστεί τεχνική αναθεώρηση [4]. Οι κυριότερες αλλαγές που εισήχθησαν με την έκδοση του 2022 περιλαμβάνουν την πλήρη ευθυγράμμιση του κειμένου οδηγίων με το πρότυπο ISO 27001:2022 και το ISO 31000:2018 [7]. Επιπρόσθετα, η ορολογία έχει προσαρμοστεί

ώστε να συμβαδίζει με αυτήν του ISO 31000:2018 [8], ενώ και η δομή των παραγράφων έχει προσαρμοστεί ώστε να ακολουθεί τη διάταξη του ISO/IEC 27001:2022 [9]. Σημειώνεται ότι το πρότυπο έχει υιοθετηθεί αυτούσιο στην ελληνική τυποποίηση ως ΕΛΟΤ EN ISO/IEC 27005:2024.

2.1.3 Νομική Φύση

Όσον αφορά τη νομική του φύση, το ISO 27005:2022 αποτελεί ένα Διεθνές Πρότυπο εθελοντικής εφαρμογής και όχι νομική ή κανονιστική διάταξη. Στον πρόλογο του εγγράφου γίνεται ρητή αναφορά στην εθελοντική φύση των προτύπων, παραπέμποντας σε ειδική επεξήγηση του οργανισμού για το θέμα αυτό [10].

Ο χαρακτήρας του εγγράφου είναι σαφώς συμβουλευτικός και όχι υποχρεωτικός, καθώς ορίζεται ως «Καθοδήγηση» (Guidance) για τη διαχείριση κινδύνων ασφάλειας πληροφοριών. Σκοπός του είναι να παρέχει οδηγίες για να βοηθήσει τους οργανισμούς να εκπληρώσουν τις απαιτήσεις του ISO 27001 και να εκτελέσουν δραστηριότητες διαχείρισης κινδύνου, χωρίς να επιβάλλει κυρώσεις για τη μη εφαρμογή του [11].

2.1.4 Γεωγραφική Εμβέλεια

Ως διεθνές πρότυπο (International Standard), το ISO 27005 έχει παγκόσμια γεωγραφική εμβέλεια και αναγνώριση. Το σύστημα τυποποίησης που συγκροτούν ο ISO και η IEC είναι εξειδικευμένο για την παγκόσμια τυποποίηση (worldwide standardization), διασφαλίζοντας ότι τα πρότυπα που εκδίδονται γίνονται αποδεκτά διεθνώς [12]. Η ανάπτυξη του προτύπου βασίζεται στη συμμετοχή εθνικών φορέων από όλο τον κόσμο, οι οποίοι λαμβάνουν μέρος στις τεχνικές επιτροπές, εξασφαλίζοντας έτσι την αντιπροσωπευτικότητα και την παγκόσμια συναίνεση [13]. Επιπλέον, το πεδίο εφαρμογής του δεν περιορίζεται γεωγραφικά ή κλαδικά. Το έγγραφο ορίζει ρητά ότι είναι εφαρμόσιμο σε όλους τους οργανισμούς, ανεξαρτήτως του τύπου, του μεγέθους ή του τομέα δραστηριότητάς τους, καθιστώντας το κατάλληλο για χρήση από πολυεθνικές επιχειρήσεις έως μικρές τοπικές εταιρείες σε οποιαδήποτε χώρα [14].

2.1.5 Κόστος Πρόσβασης

Το πρότυπο ISO/IEC 27005 δεν διατίθεται ελεύθερα, αλλά αποτελεί έγγραφο προστατευόμενο από πνευματικά δικαιώματα (Copyright Protected Document) [15]. Η ιδιοκτησία του ανήκει στον οργανισμό έκδοσης και η πρόσβαση σε αυτό ελέγχεται αυστηρά. Για την περίπτωση της Ελλάδας, το επίσημο κόστος αγοράς του προτύπου (ΕΛΟΤ EN ISO/IEC 27005:2024) από τον Ελληνικό Οργανισμό Τυποποίησης (ΕΛΟΤ) ανέρχεται στα 95,00 €, σύμφωνα με τον ισχύοντα τιμοκατάλογο του οργανισμού [16].

Επιπρόσθετα του κόστους κτήσης, η εφαρμογή του προτύπου συνεπάγεται εσωτερικό κόστος για τον οργανισμό, καθώς απαιτεί τη δέσμευση συγκεκριμένων πόρων. Σύμφωνα με το έγγραφο, η ανώτατη διοίκηση οφείλει να διασφαλίζει ότι διατίθενται οι αναγκαίοι πόροι (resources) για τη διαχείριση του κινδύνου [17].

Το λειτουργικό κόστος εξαρτάται από τρεις βασικούς παράγοντες που προσδιορίζονται στο πρότυπο:

1. Χρηματοδότηση και Προϋπολογισμός: Η διενέργεια των αξιολογήσεων κινδύνου πρέπει να λαμβάνει υπόψη τους επιχειρηματικούς κύκλους προϋπολογισμού (budget cycles) και να προγραμματίζεται εγκαίρως ώστε να εγκρίνονται τα απαραίτητα κονδύλια [18].
2. Τεχνογνωσία και Ανθρώπινο Δυναμικό: Απαιτούνται άτομα με την κατάλληλη εμπειρογνωμοσύνη (expertise) για τη διεξαγωγή των δοκιμών και των αναλύσεων [19].
3. Τεχνολογία και Εργαλεία: Η επιλογή των μεθόδων αξιολόγησης (π.χ. έλεγχοι ευπαθειών) εξαρτάται άμεσα από τα διαθέσιμα κεφάλαια και την υπάρχουσα τεχνολογία (available technology) [19].

Τέλος, στο πλαίσιο της συνεχούς βελτίωσης, ο οργανισμός καλείται να παρακολουθεί το συνολικό κόστος ιδιοκτησίας (total cost of ownership) της διαδικασίας διαχείρισης κινδύνου [20].

2.2 Σκοπός και αρχιτεκτονική

2.2.1 Επίπεδο εστίασης

Το ISO 27005 υιοθετεί μια προσέγγιση που διατρέχει τον οργανισμό, συνδέοντας το στρατηγικό επίπεδο με το επιχειρησιακό. Το πεδίο εφαρμογής του είναι ευρύ και μπορεί να καλύψει το σύνολο ενός οργανισμού ή συγκεκριμένα τμήματά του (π.χ. ένα τμήμα πληροφορικής), ανεξαρτήτως μεγέθους ή τομέα δραστηριότητας [21]. Βασικό χαρακτηριστικό της εστιάσής του είναι ο προσανατολισμός στους επιχειρηματικούς στόχους. Ο ίδιος ο ορισμός του κινδύνου στο πρότυπο περιγράφεται ως «η επίδραση της αβεβαιότητας στους στόχους» [22]. Συνεπώς, η διαδικασία διαχείρισης κινδύνου εστιάζει πρωτίστως στη λήψη αποφάσεων που επηρεάζουν την επίτευξη των στόχων του οργανισμού [23].

Για να γεφυρώσει το χάσμα μεταξύ στρατηγικής και τεχνολογίας, το πρότυπο διακρίνει τα περιουσιακά στοιχεία (assets) σε δύο επίπεδα:

1. **Πρωτεύοντα ή Επιχειρησιακά Περιουσιακά Στοιχεία (Primary/Business Assets):** Αφορούν τις πληροφορίες και τις επιχειρησιακές διαδικασίες που έχουν αξία για τον οργανισμό.
2. **Υποστηρικτικά Περιουσιακά Στοιχεία (Supporting Assets):** Αφορούν τα στοιχεία του πληροφοριακού συστήματος (Hardware, Software, Δίκτυα, Προσωπικό) πάνω στα οποία βασίζονται τα πρωτεύοντα στοιχεία [24].

Μέσω αυτής της δομής, το πρότυπο εστιάζει στο πώς οι τεχνικές ευπάθειες των υποστηρικτικών στοιχείων μπορούν να επηρεάσουν τις επιχειρηματικές διαδικασίες, καλύπτοντας έτσι ταυτόχρονα το επίπεδο του πληροφοριακού συστήματος και το επίπεδο της επιχειρησιακής διαδικασίας.

2.2.2 Σχέση με άλλα πρότυπα

Το ISO 27005 δεν λειτουργεί αυτόνομα, αλλά αποτελεί αναπόσπαστο μέρος της οικογένειας προτύπων ISO 27000. Συγκεκριμένα, έχει σχεδιαστεί για να υποστηρίζει την εφαρμογή του συστήματος διαχείρισης ασφάλειας πληροφοριών (ISMS) που καθορίζεται στο πρότυπο ISO 27001 [25].

Ο ρόλος του είναι συμπληρωματικός και καθοδηγητικός. Ενώ το ISO 27001 θέτει τις απαιτήσεις (requirements) για τη διαχείριση κινδύνων, το ISO 27005 παρέχει την καθοδήγηση (guidance) για το πώς να ικανοποιηθούν αυτές οι απαιτήσεις [26]. Επιπλέον, το έγγραφο λειτουργεί συμπληρωματικά προς το ISO 27003, το οποίο αφορά γενικότερα την υλοποίηση ενός ISMS [27].

Σε ευρύτερο πλαίσιο, το πρότυπο είναι πλήρως ευθυγραμμισμένο με το ISO 31000, το οποίο αποτελεί το γενικό πρότυπο για τη διαχείριση κινδύνων (ανεξαρτήτως κλάδου). Το ISO 27005 ουσιαστικά προσαρμόζει τις γενικές αρχές του ISO 31000 στο ειδικό περιβάλλον της ασφάλειας πληροφοριών [28]. Τέλος, για την ορολογία του βασίζεται στο πρότυπο ISO 27000, το οποίο παρέχει το λεξιλόγιο της οικογένειας [29].

2.2.3 Κύκλος Διαχείρισης

Η αρχιτεκτονική του ISO 27005 δεν είναι γραμμική, αλλά βασίζεται σε μια επαναληπτική προσέγγιση [30]. Η διαδικασία διαχείρισης κινδύνου ευθυγραμμίζεται με το γενικό μοντέλο του ISO 31000 και περιλαμβάνει τα στάδια: Καθορισμός Πλαισίου, Αξιολόγηση Κινδύνου (Αναγνώριση, Ανάλυση, Αποτίμηση), Αντιμετώπιση, Παρακολούθηση και Επικοινωνία όπως φαίνεται στο παρακάτω σχεδιάγραμμα [31].

Το πρότυπο διακρίνει ρητά δύο κύκλους διαχείρισης που πρέπει να λειτουργούν παράλληλα:

1. **Στρατηγικός Κύκλος (Strategic cycle):** Αφορά μακροπρόθεσμες αλλαγές στο γενικό πλαίσιο του οργανισμού, όπου τα επιχειρηματικά περιουσιακά στοιχεία, οι πηγές κινδύνου και οι στόχοι εξελίσσονται [32].
2. **Επιχειρησιακός Κύκλος (Operational cycle):** Αφορά βραχύτερα χρονικά διαστήματα και εστιάζει στην αναθεώρηση και ενημέρωση των σεναρίων κινδύνου και της αντιμετώπισής τους, βάσει νέων στοιχείων ή αλλαγών κριτηρίων [33].

Τέλος, η όλη διαδικασία διέπεται από την αρχή της Συνεχούς Βελτίωσης. Το πρότυπο απαιτεί η διαδικασία διαχείρισης κινδύνου να παρακολουθείται, να ανασκοπείται και να βελτιώνεται συνεχώς, ώστε να παραμένει σχετική με τους

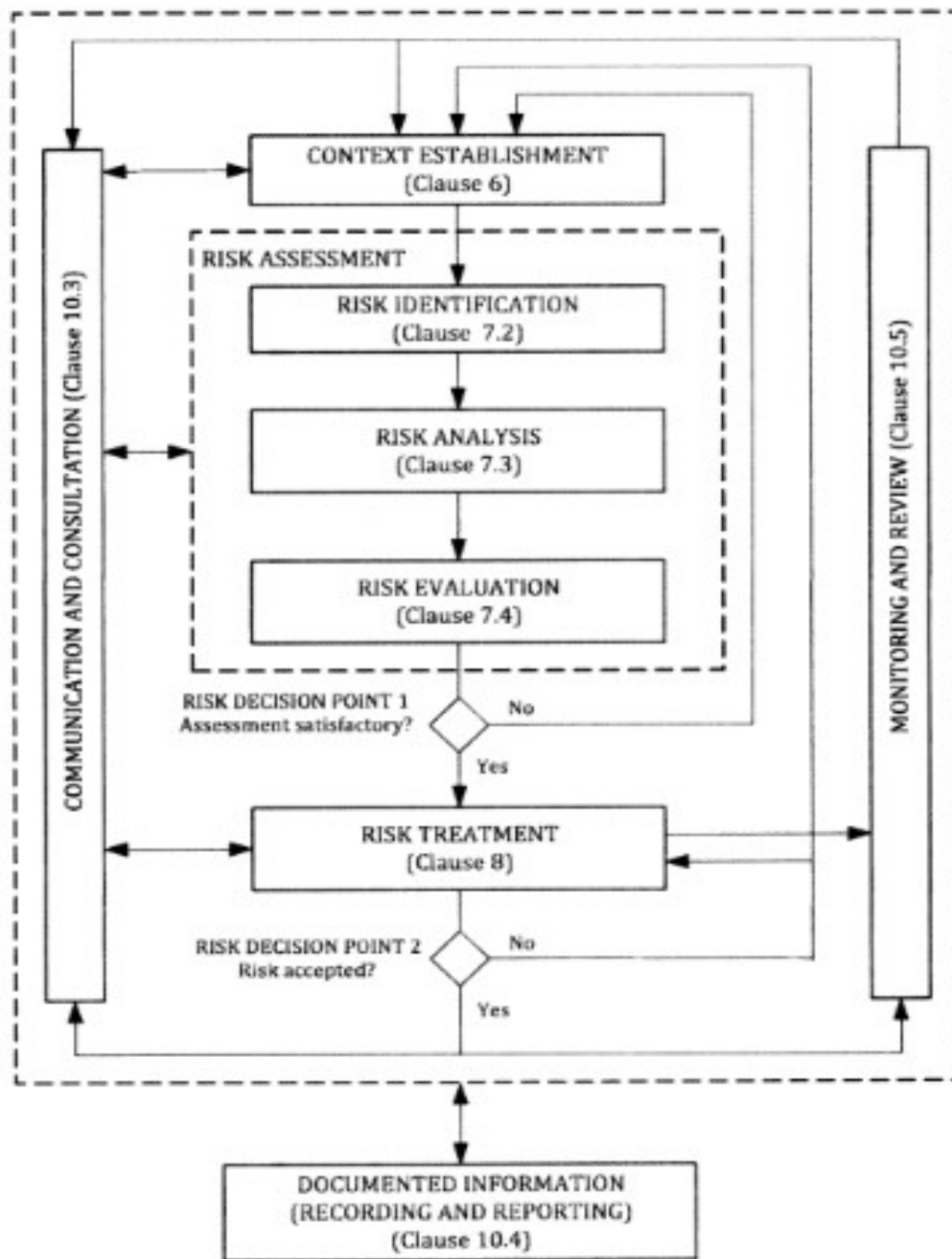


Figure 1 — Information security risk management process

2.3 Μεθοδολογία Αξιολόγησης Κινδύνου

2.3.1 Προσέγγιση αξιολόγησης

Το ISO 27005 δεν επιβάλλει μια μοναδική, υποχρεωτική μέθοδο για την εκτέλεση της αξιολόγησης κινδύνου, αφήνοντας στον οργανισμό την ελευθερία να επιλέξει αυτή που ταιριάζει στις ανάγκες του. Βασική απαίτηση είναι η επιλεγμένη μέθοδος να διασφαλίζει ότι τα αποτελέσματα των επαναλαμβανόμενων αξιολογήσεων είναι συνεπή, έγκυρα και συγκρίσιμα [35]. Ωστόσο, το πρότυπο διακρίνει και προτείνει δύο κύριες προσεγγίσεις για την αναγνώριση των κινδύνων [36]:

a) **Προσέγγιση βάσει Συμβάντων (Event-based approach):** Αυτή η προσέγγιση εστιάζει στον εντοπισμό «στρατηγικών σεναρίων» (strategic scenarios). Εξετάζει τις πηγές κινδύνου και τον τρόπο με τον οποίο αυτές αλληλεπιδρούν με τα ενδιαφερόμενα μέρη για να επιτύχουν τους στόχους τους [37].

- Είναι ιδανική για τη δημιουργία σεναρίων υψηλού επιπέδου, χωρίς να απαιτείται η κατανάλωση σημαντικού χρόνου για τη λεπτομερή καταγραφή όλων των περιουσιακών στοιχείων [38].
- Συχνά βασίζεται στην ανακάλυψη των ανησυχιών της ανώτατης διοίκησης και επιτρέπει στον οργανισμό να εστιάσει τις προσπάθειες αντιμετώπισης στους κρίσιμους κινδύνους [38].

b) **Προσέγγιση βάσει Περιουσιακών Στοιχείων (Asset-based approach):** Αυτή είναι η προσέγγιση που εστιάζει στον εντοπισμό «επιχειρησιακών σεναρίων» (operational scenarios), τα οποία είναι λεπτομερή ως προς τα περιουσιακά στοιχεία, τις απειλές και τις ευπάθειες [39].

- Βασίζεται στην έννοια ότι ο κίνδυνος προκύπτει από την εξέταση ενός περιουσιακού στοιχείου (asset), όπου ως τέτοιο ορίζεται οτιδήποτε έχει αξία για τον οργανισμό και απαιτεί προστασία [40].
- Η μέθοδος αυτή επιτρέπει τον εντοπισμό απειλών και ευπαθειών που αφορούν συγκεκριμένα πάγια, οδηγώντας στον καθορισμό λεπτομερών μέτρων αντιμετώπισης [41].

Σχέση των δύο προσεγγίσεων: Στην ουσία, οι δύο προσεγγίσεις περιγράφουν το ίδιο σενάριο κινδύνου αλλά κινούνται προς αντίθετες κατευθύνσεις. Η προσέγγιση βάσει συμβάντων ξεκινά από το γενικό επίπεδο του σεναρίου και εμβαθύνει προς τις λεπτομέρειες για να εντοπίσει τις πηγές του κινδύνου (drill down) [42]. Αντίθετα, η προσέγγιση βάσει περιουσιακών στοιχείων ξεκινά από το συγκεκριμένο πάγιο και ερευνά προς τα πάνω προς το σενάριο, με σκοπό να αναδείξει πώς οι επιμέρους συνέπειες αθροίζονται και εξελίσσονται για να επηρεάσουν τελικά τον οργανισμό [43].

2.3.2 Ευελιξία μεθοδολογίας

Η μεθοδολογία του ISO 27005 χαρακτηρίζεται από υψηλό βαθμό ευελιξίας και μη κανονιστικό χαρακτήρα. Το πρότυπο δηλώνει ρητά ότι δεν επιβάλλει μια συγκεκριμένη προσέγγιση ή μέθοδο για την ικανοποίηση των απαιτήσεων διαχείρισης κινδύνου, επιτρέποντας στον οργανισμό να επιλέξει ή να αναπτύξει τη μέθοδο που ταιριάζει καλύτερα στις ανάγκες του [44].

Σε αντίθεση με τα «συνταγογραφικά» πρότυπα που ορίζουν αυστηρούς μαθηματικούς τύπους, το ISO 27005 λειτουργεί ως πλαίσιο αναφοράς. Παρέχει στον οργανισμό τη διακριτική ευχέρεια να επιλέξει μεταξύ τριών τύπων τεχνικών ανάλυσης, ανάλογα με την ωριμότητα και τα διαθέσιμα δεδομένα [45]:

1. **Ποιοτική (Qualitative):** Χρήση περιγραφικών κλιμάκων (π.χ. Υψηλό, Μεσαίο, Χαμηλό).
2. **Ποσοτική (Quantitative):** Χρήση αριθμητικών τιμών (π.χ. χρηματικό κόστος ή πιθανότητα εμφάνισης).
3. **Ημι-ποσοτική (Semiquantitative):** Χρήση ποιοτικών κλιμάκων στις οποίες έχουν αποδοθεί τιμές.

Αν και το πρότυπο παρέχει δείγματα (Παράρτημα Α), διευκρινίζει ρητά ότι αυτά αποτελούν απλώς παραδείγματα. Οι κατηγορίες και οι τιμές που παρουσιάζονται δεν είναι δεσμευτικές [46]. Αντιθέτως, τονίζεται ότι κανένας οργανισμός δεν είναι πιθανό να καλύπτεται πλήρως από τις κλίμακες των παραδειγμάτων και ότι το πλαίσιο και το πεδίο εφαρμογής του οργανισμού θα πρέπει να χρησιμοποιούνται για τον καθορισμό ρεαλιστικών ορίων [47].

2.3.3 Τεχνική υπολογισμού ρίσκου

Η τεχνική υπολογισμού του επιπέδου κινδύνου (level of risk) στο ISO 27005 δεν περιορίζεται σε έναν μοναδικό αλγόριθμο, αλλά μπορεί να καθοριστεί με πολλούς πιθανούς τρόπους. Ωστόσο, η πιο κοινή πρακτική που περιγράφεται είναι ο καθορισμός του κινδύνου ως συνδυασμός της εκτιμώμενης πιθανότητας και των εκτιμώμενων συνεπειών για όλα τα σχετικά σενάρια [48]. Το πρότυπο παρέχει σημαντική ελευθερία ως προς τη διαμόρφωση του μαθηματικού τύπου ή της λογικής σχέσης:

- **Συμπερίληψη Αξίας Παγίου:** Εναλλακτικοί υπολογισμοί μπορούν να συμπεριλάβουν ρητά την αξία του περιουσιακού στοιχείου (asset value) ως τρίτη παράμετρο, μαζί με την πιθανότητα και τη συνέπεια [49].
- **Μη Γραμμικοί Υπολογισμοί:** Η σχέση μεταξύ των παραγόντων δεν είναι απαραίτητα γραμμική (π.χ. όχι μία απλή πράξη αλλά πιο πολύπλοκη) [50].

Σε κάθε περίπτωση, ο υπολογισμός πρέπει να καταλήγει σε αποτελέσματα που είναι σύμφωνα με τα κριτήρια κινδύνου που έχει θεσπίσει ο οργανισμός κατά τη φάση δημιουργίας του πλαισίου [51].

2.3.4 Κατάλογοι απειλών/ευπαθειών

Όσον αφορά την αναγνώριση των κινδύνων, το ISO 27005 δεν επιβάλλει μια κλειστή, υποχρεωτική ταξινόμια, αλλά παρέχει εκτενείς καταλόγους που λειτουργούν ως παραδείγματα προς χρήση κατά τη διαδικασία αξιολόγησης [52]. Συγκεκριμένα, το πρότυπο περιλαμβάνει:

- **Κατάλογο Απειλών (Table A.10):** Παρέχει παραδείγματα τυπικών απειλών, τα οποία μπορούν να χρησιμοποιηθούν κατά τη διαδικασία αξιολόγησης απειλών [52]. Οι απειλές αυτές κατηγοριοποιούνται ανάλογα με την πηγή τους σε σκόπιμες (deliberate), τυχαίες (accidental) ή περιβαλλοντικές (environmental) [53].
- **Κατάλογο Ευπαθειών (Table A.11):** Παρέχει παραδείγματα ευπαθειών σε διάφορους τομείς ασφάλειας (Υλικό, Λογισμικό, Δίκτυο, Προσωπικό, Εγκαταστάσεις, Οργάνωση), καθώς και παραδείγματα απειλών που μπορούν να εκμεταλλευτούν αυτές τις ευπάθειες [54].

Οι κατάλογοι αυτοί έχουν σχεδιαστεί για να παρέχουν βοήθεια (guidance) στον οργανισμό ώστε να προσδιορίσει τα σχετικά σενάρια κινδύνου. Ωστόσο, τονίζεται ότι δεν είναι εξαντλητικοί και ότι σε ορισμένες περιπτώσεις ενδέχεται να υπάρχουν και άλλες απειλές που εκμεταλλεύονται τις ευπάθειες αυτές, οπότε εναπόκειται στον οργανισμό να προσαρμόσει τις λίστες στο δικό του πλαίσιο λειτουργίας [55].

2.4 Πόροι και Εφαρμογή

2.4.1 Πολυπλοκότητα υλοποίησης

Η πολυπλοκότητα εφαρμογής του ISO 27005 πηγάζει πρωτίστως από την ευελιξία του. Καθώς το πρότυπο δεν προσφέρει έτοιμες λύσεις, απαιτεί από τον εκάστοτε οργανισμό να αφιερώσει σημαντική προσπάθεια στη φάση της καθιέρωσης του πλαισίου (Context Establishment) για να συναρμολογήσει το εσωτερικό και εξωτερικό περιβάλλον διαχείρισης [56].

Ο οργανισμός καλείται να ορίσει μόνος του τις παραμέτρους λειτουργίας, όπως τα κριτήρια κινδύνου (κριτήρια αποδοχής και αξιολόγησης) [57], καθώς και να επιλέξει την κατάλληλη μέθοδο που θα διασφαλίζει ότι τα αποτελέσματα είναι συνεπή, έγκυρα και συγκρίσιμα [58].

Όσον αφορά το προσωπικό, η διαδικασία δεν μπορεί να διεκπεραιωθεί μηχανικά. Απαιτείται η εμπλοκή ατόμων με εξειδικευμένες γνώσεις στο σχετικό πεδίο για τη συλλογή των απαραίτητων πληροφοριών και την ορθή εκτίμηση των κινδύνων [59]. Μάλιστα, ειδικά όταν χρησιμοποιούνται ποιοτικές μέθοδοι, το πρότυπο τονίζει ότι οι αναλυτές κινδύνου θα πρέπει να λαμβάνουν εκπαίδευση και να κάνουν περιοδική εξάσκηση, ώστε να διατηρούν την ευθυγράμμιση της κρίσης τους και να μειώνουν την υποκειμενικότητα [60].

2.4.2 Απαιτούμενοι πόροι (κόστος εφαρμογής)

Η εφαρμογή του ISO 27005 συνεπάγεται σημαντικό λειτουργικό κόστος, το οποίο δεν αφορά την αγορά του προτύπου ή κάποιου εξειδικευμένου λογισμικού, αλλά πρωτίστως τη δέσμευση ανθρώπινου δυναμικού και διοικητικού χρόνου. Η ανώτατη διοίκηση φέρει την ευθύνη να διασφαλίζει ότι διατίθενται οι απαραίτητοι πόροι για τη διαχείριση του κινδύνου [61].

α) Δέσμευση ανθρώπινου δυναμικού και συνεργασία: Η μεθοδολογία δεν μπορεί να εφαρμοστεί από ένα άτομο απομονωμένα. Απαιτεί εκτεταμένη αλληλεπίδραση εντός του οργανισμού:

- **Συνεντεύξεις:** Η αναγνώριση κινδύνων απαιτεί χρόνο για συνεντεύξεις με τη διοίκηση και τους υπεύθυνους επιχειρησιακών διαδικασιών, ώστε να εντοπιστούν τα σχετικά συμβάντα [62].
- **Ομαδική Αξιολόγηση:** Για την αύξηση της αξιοπιστίας στις εκτιμήσεις πιθανοτήτων, το πρότυπο προτείνει τη διενέργεια ομαδικών αξιολογήσεων

(team assessments) αντί ατομικών, δεσμεύοντας έτσι περισσότερα στελέχη [63].

- **Συνεχής Επικοινωνία:** Η επικοινωνία και η διαβούλευση με τα ενδιαφερόμενα μέρη πρέπει να είναι συνεχής (continual) και όχι εφάπαξ [64].

β) Οικονομικός Προγραμματισμός: Η διαδικασία είναι άρρηκτα συνδεδεμένη με τους οικονομικούς κύκλους του οργανισμού. Οι αξιολογήσεις κινδύνου πρέπει να προγραμματίζονται εγκαίρως ώστε να εντάσσονται στον ετήσιο προϋπολογισμό για την έγκριση κονδυλίων υλοποίησης μέτρων, ενώ ο οργανισμός καλείται να παρακολουθεί το συνολικό κόστος ιδιοκτησίας της διαδικασίας [65].

γ) Τεκμηρίωση (Γραφειοκρατία): Το πρότυπο επιβάλλει αυστηρές απαιτήσεις τεκμηρίωσης, καθώς η ύπαρξη τεκμηριωμένων πληροφοριών (documented information) είναι υποχρεωτική για την απόδειξη συμμόρφωσης [66]. Ο οργανισμός οφείλει να διατηρεί έγγραφα που περιγράφουν:

- Τον ορισμό των κριτηρίων και τη μεθοδολογία που επιλέχθηκε.
- Τα αποτελέσματα της αξιολόγησης (λίστες κινδύνων, ιδιοκτήτες κινδύνου).
- Τις αποφάσεις για την αντιμετώπιση και τα σχέδια θεραπείας κινδύνου [67].

3. Ανάλυση Μεθοδολογιών NIST (SP 800-30 rev.1 και SP 800-39)

3.1 Εισαγωγή

Σε αντίθεση με το πρότυπο ISO 27005 που αποτελεί ένα ενιαίο έγγραφο καθοδήγησης, η προσέγγιση του Εθνικού Ινστιτούτου Προτύπων και Τεχνολογίας των ΗΠΑ (NIST) είναι αρθρωτή και κατανέμεται σε μια σειρά εξειδικευμένων εκδόσεων (Special Publications - SP). Για τους σκοπούς της παρούσας συγκριτικής μελέτης, και προκειμένου να καλυφθεί το αντίστοιχο εύρος με αυτό του ISO 27005, εξετάζονται συνδυαστικά δύο θεμελιώδη έγγραφα:

1. **NIST SP 800-39 rev.1 (Managing Information Security Risk):** Καθορίζει το γενικό πλαίσιο για μια ολοκληρωμένη, ευρεία διαχείριση κινδύνου σε επίπεδο οργανισμού, ορίζοντας τη στρατηγική, τη διακυβέρνηση και την παρακολούθηση [68].
2. **NIST SP 800-30 Rev.1 (Guide for Conducting Risk Assessments):** Λειτουργεί ως υποστηρικτικό έγγραφο, παρέχοντας εξειδικευμένες οδηγίες αποκλειστικά για τη διεξαγωγή της διαδικασίας αξιολόγησης κινδύνου (Risk Assessment). Σκοπός του είναι να εξειδικεύσει και να εφαρμόσει τις οδηγίες του SP 800-39 rev.1 στο επιχειρησιακό επίπεδο [69].

Η συνδυαστική ανάλυση των δύο αυτών εγγράφων είναι απαραίτητη, καθώς το μεν SP 800-39 θέτει το στρατηγικό πλαίσιο, το δε SP 800-30 αναλύει τον τρόπο εκτέλεσης της αξιολόγησης, καλύπτοντας έτσι ολιστικά τον κύκλο ζωής διαχείρισης κινδύνου [70].

3.2 Ταυτότητα και προέλευση

3.2.1 Φορέας Έκδοσης και Προέλευση

Τα έγγραφα της σειράς Special Publications 800 (SP 800) εκδίδονται από το Εθνικό Ινστιτούτο Προτύπων και Τεχνολογίας (NIST), το οποίο αποτελεί υπηρεσία του Υπουργείου Εμπορίου των Ηνωμένων Πολιτειών (U.S. Department of Commerce)

[71]. Η ανάπτυξη των συγκεκριμένων οδηγιών απορρέει από τις θεσμικές υποχρεώσεις του NIST βάσει του ομοσπονδιακού νόμου για τη Διαχείριση της Ασφάλειας Πληροφοριών του 2002 (FISMA - Federal Information Security Management Act, Public Law 107-347) [72]. Ο νόμος αυτός αναθέτει στο NIST την ευθύνη για την ανάπτυξη προτύπων και κατευθυντήριων γραμμών, συμπεριλαμβανομένων των ελάχιστων απαιτήσεων, για την ασφάλεια των πληροφοριακών συστημάτων των ομοσπονδιακών υπηρεσιών [73].

Σημαντικό στοιχείο της προέλευσής τους είναι ότι αμφότερα τα έγγραφα αναπτύχθηκαν στο πλαίσιο της πρωτοβουλίας Joint Task Force Transformation Initiative. Πρόκειται για μια διυπηρεσιακή συνεργασία που περιλαμβάνει εκπροσώπους από τις κοινότητες των πολιτικών υπηρεσιών, της άμυνας και των μυστικών υπηρεσιών (Civil, Defense, and Intelligence Communities), με στόχο τη δημιουργία ενός ενοποιημένου πλαισίου ασφάλειας πληροφοριών για την ομοσπονδιακή κυβέρνηση των ΗΠΑ [74].

3.2.2 Τρέχουσα Έκδοση

Για τους σκοπούς της παρούσας μελέτης, και προκειμένου να υπάρχει πλήρης συμβατότητα με τις σύγχρονες απαιτήσεις, εξετάζονται οι τρέχουσες, ισχύουσες εκδόσεις των δύο εγγράφων:

1. **NIST SP 800-39:** Η τρέχουσα έκδοση του εγγράφου δημοσιεύθηκε τον **Μάρτιο του 2011** [75]. Αξίζει να σημειωθεί ότι το έγγραφο αυτό αντικατέστησε και υποκατέστησε την αρχική έκδοση του SP 800-30 ως η πρωταρχική πηγή καθοδήγησης για τη συνολική διαχείριση κινδύνου [76].
2. **NIST SP 800-30 Rev.1:** Η τρέχουσα έκδοση είναι η Αναθεώρηση 1 (Revision 1) και δημοσιεύθηκε τον Σεπτέμβριο του 2012 [77]. Η αναθεώρηση αυτή εκδόθηκε για να ευθυγραμμίσει τη διαδικασία αξιολόγησης με το νέο στρατηγικό πλαίσιο που έθεσε το SP 800-39.

3.2.3 Νομική Φύση

Η νομική φύση των εγγράφων του NIST διαφοροποιείται σημαντικά ανάλογα με τον οργανισμό που τα εφαρμόζει, παρουσιάζοντας έναν διττό χαρακτήρα:

1. **Υποχρεωτική Εφαρμογή (Mandatory):** Για τις ομοσπονδιακές υπηρεσίες των Ηνωμένων Πολιτειών (Federal Agencies), η συμμόρφωση με τα πρότυπα και τις οδηγίες ασφαλείας του NIST είναι υποχρεωτική και δεσμευτική. Αυτό απορρέει από τις κανονιστικές απαιτήσεις του νόμου FISMA και τις οδηγίες του Γραφείου Διαχείρισης και Προϋπολογισμού (OMB) [78].
2. **Εθελοντική Εφαρμογή (Voluntary):** Για μη κυβερνητικούς οργανισμούς, ακαδημαϊκά ιδρύματα και επιχειρήσεις του ιδιωτικού τομέα (εντός και εκτός ΗΠΑ), η χρήση των εγγράφων αυτών είναι προαιρετική. Οι οργανισμοί αυτοί μπορούν να τα υιοθετήσουν εθελοντικά ως πλαίσιο βέλτιστων πρακτικών για τη διαχείριση κινδύνου [79].

Επιπλέον, ως έργα της ομοσπονδιακής κυβέρνησης των ΗΠΑ, τα έγγραφα αυτά δεν υπόκεινται σε πνευματικά δικαιώματα εντός των Ηνωμένων Πολιτειών και μπορούν να χρησιμοποιηθούν ελεύθερα, αν και το NIST ζητά την αναφορά της πηγής κατά τη χρήση τους [80].

3.2.4 Γεωγραφική Εμβέλεια

Τυπικά, η γεωγραφική εμβέλεια των οδηγιών του NIST περιορίζεται στην επικράτεια των Ηνωμένων Πολιτειών και συγκεκριμένα στα πληροφοριακά συστήματα της ομοσπονδιακής κυβέρνησης. Τα έγγραφα ορίζουν ρητά ότι οι κατευθυντήριες γραμμές τους εφαρμόζονται σε όλα τα ομοσπονδιακά πληροφοριακά συστήματα (εκτός από τα συστήματα εθνικής ασφάλειας, εκτός αν εγκριθεί ρητά η χρήση τους και για αυτά) [81].

Ωστόσο, η πραγματική εμβέλειά τους είναι παγκόσμια. Το NIST ενθαρρύνει ρητά τις πολιτειακές, τοπικές και φυλετικές κυβερνήσεις, καθώς και τους οργανισμούς του ιδιωτικού τομέα, να εξετάσουν τη χρήση αυτών των οδηγιών [82]. Επιπλέον, καταβάλλεται συνειδητή προσπάθεια εναρμόνισης με τα διεθνή πρότυπα. Οι έννοιες και οι αρχές των εγγράφων έχουν σχεδιαστεί ώστε να είναι συμβατές με τα πρότυπα του Διεθνούς Οργανισμού Τυποποίησης (ISO/IEC), μειώνοντας έτσι τον φόρτο για τους οργανισμούς που πρέπει να συμμορφώνονται τόσο με τα πρότυπα NIST όσο και με τα διεθνή πρότυπα ISO [83].

3.2.5 Κόστος Πρόσβασης

Σε πλήρη αντίθεση με τα πρότυπα του ISO που απαιτούν την αγορά άδειας χρήσης, η πρόσβαση στα έγγραφα της σειράς NIST SP 800 είναι δωρεάν και ανοικτή στο κοινό. Τα έγγραφα NIST SP 800-39 και NIST SP 800-30 Rev.1, ως έργα που αναπτύχθηκαν από ομοσπονδιακή υπηρεσία των Η.Π.Α. (NIST), δεν υπόκεινται σε περιορισμούς πνευματικών δικαιωμάτων (copyright) εντός των Ηνωμένων Πολιτειών. Αυτό σημαίνει ότι μπορούν να χρησιμοποιηθούν, να αντιγραφούν και να διανεμηθούν ελεύθερα από μη κυβερνητικούς οργανισμούς σε εθελοντική βάση [84]. Το μόνο που ζητά το NIST είναι η αναφορά της πηγής κατά τη χρήση τους [85]. Όλες οι εκδόσεις είναι άμεσα διαθέσιμες για λήψη σε ηλεκτρονική μορφή (PDF) μέσω της επίσημης ιστοσελίδας του Computer Security Resource Center (CSRC) του NIST [86].

3.3 Σκοπός και αρχιτεκτονική

3.3.1 Επίπεδο εστίασης

Σε αντίθεση με την ενιαία προσέγγιση άλλων προτύπων, η αρχιτεκτονική του NIST (όπως ορίζεται στο SP 800-39) χαρακτηρίζεται από μια αυστηρά δομημένη, πολυεπίπεδη προσέγγιση. Το πλαίσιο καθορίζει ρητά τρία ιεραρχικά επίπεδα (Tiers) διαχείρισης κινδύνου, τα οποία διατρέχουν κάθετα τον οργανισμό από το στρατηγικό έως το τακτικό επίπεδο, διασφαλίζοντας ολιστική κάλυψη [87]. Συγκεκριμένα, τα επίπεδα εστίασης είναι:

1. **Οργανισμός (Tier 1-Organization View):** Αφορά το στρατηγικό επίπεδο. Εδώ καθορίζεται η διακυβέρνηση, η στρατηγική διαχείρισης κινδύνου και η ανοχή στον κίνδυνο. Οι αποφάσεις σε αυτό το επίπεδο παρέχουν το πλαίσιο και επηρεάζουν άμεσα τις δραστηριότητες των επόμενων επιπέδων [88].
2. **Επιχειρησιακές Διαδικασίες (Tier 2-Mission/Business Process View):** Αφορά το επίπεδο της αποστολής. Εδώ ορίζονται και ιεραρχούνται οι κρίσιμες επιχειρησιακές διαδικασίες και σχεδιάζεται η επιχειρησιακή αρχιτεκτονική. Το επίπεδο αυτό λειτουργεί ως γέφυρα, μεταφράζοντας τις στρατηγικές κατευθύνσεις του Tier 1 σε συγκεκριμένες απαιτήσεις ασφαλείας για τα συστήματα [89].

3. **Πληροφοριακά Συστήματα (Tier 3-Information Systems View):** Αφορά το λειτουργικό/τεχνικό επίπεδο. Εστιάζει στα συγκεκριμένα πληροφοριακά συστήματα που υποστηρίζουν τις επιχειρησιακές διαδικασίες. Εδώ λαμβάνουν χώρα η κατηγοριοποίηση των συστημάτων, καθώς και η επιλογή, εφαρμογή και αξιολόγηση των τεχνικών μέτρων ασφαλείας [90].

Η επικοινωνία μεταξύ των επιπέδων είναι αμφίδρομη, διασφαλίζοντας ότι η στρατηγική διαχέεται προς τα συστήματα και η πληροφορία για την κατάσταση των συστημάτων ανεβαίνει προς τη διοίκηση για τη λήψη αποφάσεων [91].

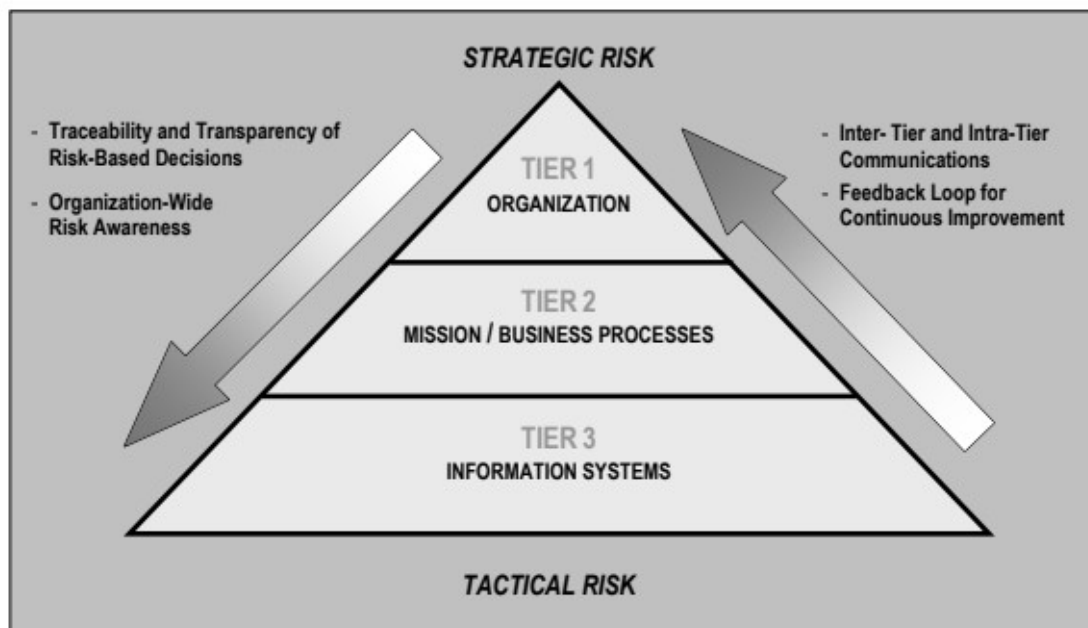


FIGURE 2: MULTITIERED ORGANIZATION-WIDE RISK MANAGEMENT

3.3.2 Σχέση με άλλα πρότυπα

Οι μεθοδολογίες NIST SP 800-39 και SP 800-30 δεν λειτουργούν ως αυτόνομες οντότητες, αλλά αποτελούν αναπόσπαστα τμήματα μιας ευρύτερης, ολοκληρωμένης σουίτας εγγράφων ασφαλείας που αναπτύχθηκε από την πρωτοβουλία Joint Task Force Transformation Initiative. Συγκεκριμένα:

- NIST SP 800-39: Χαρακτηρίζεται ρητά ως το θεμελιώδες έγγραφο της σειράς. Θέτει το στρατηγικό πλαίσιο και καθοδηγεί τα υπόλοιπα έγγραφα [92].
- NIST SP 800-30 Rev.1: Λειτουργεί υποστηρικτικά προς το SP 800-39, εξειδικεύοντας τη διαδικασία της αξιολόγησης [93].

Η εφαρμογή τους είναι άρρηκτα συνδεδεμένη με άλλα κρίσιμα πρότυπα της οικογένειας:

- NIST SP 800-37 (Risk Management Framework-RMF): Καθορίζει τον κύκλο ζωής της ασφάλειας. Η αξιολόγηση κινδύνου (του SP 800-30) εκτελείται σε συγκεκριμένα στάδια του RMF [94].
- NIST SP 800-53 (Security Controls): Παρέχει τον κατάλογο των μέτρων ασφαλείας. Οι κίνδυνοι που εντοπίζονται με το SP 800-30 αντιμετωπίζονται με την επιλογή ελέγχων από το SP 800-53 [95].

Τέλος, αξίζει να σημειωθεί η ρητή πρόθεση εναρμόνισης με τα διεθνή πρότυπα. Οι έννοιες και οι αρχές των εγγράφων αυτών έχουν σχεδιαστεί ώστε να είναι συμβατές με τα πρότυπα ISO/IEC (όπως το ISO 31000 και ISO 27005), μειώνοντας το φόρτο για τους οργανισμούς που πρέπει να συμμορφώνονται ταυτόχρονα και με τα δύο πλαίσια [96].

3.3.3 Κύκλος Διαχείρισης

Η αρχιτεκτονική του NIST δεν ακολουθεί τον κλασικό κύκλο του ISO, αλλά καθορίζει έναν εξειδικευμένο κύκλο διαχείρισης κινδύνου που αποτελείται από τέσσερα αλληλένδετα συστατικά στοιχεία. Η διαδικασία είναι ολιστική και επαναληπτική, με στόχο τη συνεχή βελτίωση [97].

Τα τέσσερα βήματα του κύκλου, όπως ορίζονται στο NIST SP 800-39, είναι:

1. **Πλαισίωση (Frame):** Καθορισμός του πλαισίου για τη λήψη αποφάσεων (υποθέσεις, περιορισμοί, ανοχή στον κίνδυνο).
2. **Αξιολόγηση (Assess):** Αναγνώριση και εκτίμηση των κινδύνων (απειλές, ευπάθειες, επιπτώσεις).
3. **Ανταπόκριση (Respond):** Λήψη μέτρων για την αντιμετώπιση του κινδύνου μόλις αυτός προσδιοριστεί.
4. **Παρακολούθηση (Monitor):** Συνεχής έλεγχος της αποτελεσματικότητας των μέτρων και των αλλαγών στο περιβάλλον [97].

Η διαδικασία αυτή περιλαμβάνει έναν βρόχο ανατροφοδότησης για τη συνεχή βελτίωση των δραστηριοτήτων [98-100].

3.4 Μεθοδολογία Αξιολόγησης Κινδύνου

3.4.1 Προσέγγιση αξιολόγησης

Το NIST SP 800-30 Rev.1 καθορίζει ρητά ότι ο κίνδυνος και οι παράγοντες που τον συνθέτουν μπορούν να αξιολογηθούν με διάφορους τρόπους. Το πρότυπο διακρίνει τρεις κύριες προσεγγίσεις αξιολόγησης, επιτρέποντας στον οργανισμό να επιλέξει αυτή που ταιριάζει καλύτερα στην κουλτούρα του και στα διαθέσιμα δεδομένα [101]:

1. **Ποσοτική Αξιολόγηση (Quantitative Assessment):** Χρησιμοποιεί αριθμούς όπου η σημασία και η αναλογικότητα των τιμών διατηρούνται αυστηρά (π.χ. χρηματικά ποσά ή ποσοστά πιθανότητας).
 - ο **Πλεονέκτημα:** Υποστηρίζει αποτελεσματικά την ανάλυση κόστους-οφέλους για την επιλογή μέτρων.
 - ο **Μειονέκτημα:** Συχνά απαιτείται ερμηνεία των αριθμών, ενώ η αυστηρότητα της μεθόδου μειώνεται όταν βασίζεται σε υποκειμενικές εκτιμήσεις ή αβέβαια δεδομένα [102].
2. **Ποιοτική Αξιολόγηση (Qualitative Assessment):** Χρησιμοποιεί μη αριθμητικές κατηγορίες ή επίπεδα (π.χ. Πολύ Χαμηλό, Χαμηλό, Μεσαίο, Υψηλό, Πολύ Υψηλό).
 - ο **Πλεονέκτημα:** Διευκολύνει την επικοινωνία των αποτελεσμάτων στα στελέχη λήψης αποφάσεων.
 - ο **Μειονέκτημα:** Το εύρος των τιμών είναι μικρό, καθιστώντας δύσκολη τη σχετική ιεράρχηση των κινδύνων, ενώ τα αποτελέσματα μπορεί να είναι υποκειμενικά αν δεν υπάρχουν σαφείς ορισμοί [103].
3. **Ημι-ποσοτική Αξιολόγηση (Semi-quantitative Assessment):** Χρησιμοποιεί κλίμακες ή αντιπροσωπευτικούς αριθμούς (π.χ. 0-10, 0-100), των οποίων οι τιμές δεν αντιστοιχούν απαραίτητα σε πραγματικά μεγέθη εκτός του πλαισίου της αξιολόγησης.
 - ο **Πλεονέκτημα:** Συνδυάζει τα οφέλη των δύο παραπάνω μεθόδων, επιτρέποντας ευκολότερη ιεράρχηση σε σχέση με την ποιοτική μέθοδο, παρέχοντας μεγαλύτερη λεπτομέρεια [104].

Η επιλογή της προσέγγισης (ή του συνδυασμού τους) εξαρτάται από την κουλτούρα του οργανισμού, ιδιαίτερα ως προς τη στάση του απέναντι στην αβεβαιότητα και την επικοινωνία του κινδύνου [105].

3.4.2 Ευελιξία μεθοδολογίας

Παρόλο που το NIST SP 800-30 Rev.1 περιέχει εξαιρετικά λεπτομερείς πίνακες και κλίμακες, το κείμενο ξεκαθαρίζει ότι η μεθοδολογία χαρακτηρίζεται από μέγιστη ευελιξία. Δεν υπάρχουν συγκεκριμένες απαιτήσεις σχετικά με την τυπικότητα, την αυστηρότητα ή το επίπεδο λεπτομέρειας μιας αξιολόγησης κινδύνου, ούτε υποχρέωση χρήσης συγκεκριμένων εργαλείων ή τεχνικών [106].

Ωστόσο, σε αντίθεση με το ISO που αφήνει τον οργανισμό να δημιουργήσει τις κλίμακες από το μηδέν, το NIST παρέχει ένα πλήρες, έτοιμο προς χρήση μοντέλο στα Παραρτήματα (Appendices D-I).

- **Χαρακτήρας Προτύπων:** Τα πρότυπα αυτά (πίνακες απειλών, κλίμακες πιθανότητας/επιπτώσεων) χαρακτηρίζονται ρητά ως «ενδεικτικά» και «προσαρμόσιμα» [107].
- **Δυνατότητα Προσαρμογής:** Οι οργανισμοί ενθαρρύνονται να χρησιμοποιήσουν αυτά τα πρότυπα ως αφετηρία και να τα προσαρμόσουν στις δικές τους ειδικές συνθήκες [108].
- **Μη Υποχρεωτική Χρήση:** Η χρήση των συγκεκριμένων πινάκων και υποδειγμάτων που παρέχονται στο έγγραφο δεν είναι υποχρεωτική για τη διενέργεια της αξιολόγησης [109].

Στην ουσία, το NIST προσφέρει μια προσέγγιση «έτοιμης λύσης» που όμως επιδέχεται μετατροπές, σε αντίθεση με την προσέγγιση του ISO. Αναγνωρίζει ότι ένα μοναδικό μοντέλο κινδύνου δεν μπορεί να καλύψει τις ποικίλες ανάγκες όλων των οργανισμών και αναμένει από τον κάθε οργανισμό να ορίσει το μοντέλο που ταιριάζει στη δική του οπτική [110].

3.4.3 Τεχνική υπολογισμού ρίσκου

Η θεμελιώδης εξίσωση του NIST ορίζει τον κίνδυνο ως συνάρτηση δύο παραγόντων: (i) της πιθανότητας εμφάνισης ενός απειλητικού συμβάντος και (ii) της δυσμενούς επίπτωσης που θα προκύψει αν το συμβάν συμβεί [111].

Για τον υπολογισμό του επιπέδου κινδύνου, το πρότυπο παρέχει λεπτομερείς πίνακες και κλίμακες:

1. Κλίμακες Μέτρησης (Scales): Το NIST προτείνει τη χρήση μιας κλίμακας 5 επιπέδων για όλους τους παράγοντες (Απειλή, Ευπάθεια, Πιθανότητα, Επίπτωση). Τα επίπεδα είναι: Πολύ Χαμηλό, Χαμηλό, Μεσαίο, Υψηλό, Πολύ Υψηλό (Very Low, Low, Moderate, High, Very High) [112].

- Στην **Ημι-ποσοτική** προσέγγιση, τα επίπεδα αυτά αντιστοιχίζονται σε αριθμητικά σκορ (π.χ. 0-100), επιτρέποντας μεγαλύτερη ακρίβεια στην ιεράρχηση [113].

2. Πίνακας Κινδύνου (Risk Matrix): Ο υπολογισμός πραγματοποιείται συνήθως μέσω ενός πίνακα (μήτρα), όπως ορίζεται στον Πίνακα I-2 (Table I-2). Εκεί συνδυάζονται η Πιθανότητα (γραμμές) και η Επίπτωση (στήλες) για να εξαχθεί το τελικό επίπεδο κινδύνου. Για παράδειγμα, εάν η Πιθανότητα είναι «Υψηλή» και η Επίπτωση «Μέτρια», ο Κίνδυνος υπολογίζεται ως «Υψηλός» [114].

3. Ευελιξία στον Υπολογισμό: Το πρότυπο αναγνωρίζει ότι ο κίνδυνος μπορεί να μην είναι απλώς ένας αριθμός, αλλά ένα διάνυσμα. Αυτό σημαίνει ότι ο κίνδυνος μπορεί να αναπαρασταθεί με πολλαπλές τιμές, όπου διαφορετικοί τύποι επιπτώσεων (π.χ. οικονομική ζημιά vs φήμη) αξιολογούνται ξεχωριστά, αντί να αθροίζονται σε ένα μοναδικό σκορ [115].

Τέλος, το NIST δίνει μεγάλη έμφαση στην καταγραφή της αβεβαιότητας. Ο υπολογισμός πρέπει να συνοδεύεται από μια εκτίμηση της αβεβαιότητας που πηγάζει από ελλιπή δεδομένα ή υποκειμενικές κρίσεις [116].

3.4.4 Κατάλογοι απειλών/ευπαθειών

Σε αντίθεση με την πιο γενική προσέγγιση άλλων προτύπων, το NIST SP 800-30 Rev.1 παρέχει εξαιρετικά λεπτομερείς και έτοιμους προς χρήση καταλόγους (taxonomies) στα παραρτήματά του. Η στρατηγική που προτείνεται στον οργανισμό δεν είναι η ανακάλυψη των απειλών από το μηδέν, αλλά η χρήση αυτών των καταλόγων ως σημείο εκκίνησης με την κατάλληλη προσαρμογή [117].

Συγκεκριμένα, το πρότυπο περιλαμβάνει:

1. **Ταξινόμια Πηγών Απειλών (Threat Sources):** Κατηγοριοποιεί τις πηγές σε τέσσερις βασικές ομάδες: (i) Εχθρικές (Adversarial), (ii) Τυχαίες (Accidental), (iii) Δομικές (Structural), και (iv) Περιβαλλοντικές (Environmental) [118]. Παρέχει πίνακες για την αξιολόγηση των χαρακτηριστικών τους, όπως η ικανότητα (capability), η πρόθεση (intent) και η στόχευση (targeting) [119].
2. **Κατάλογο Συμβάντων Απειλής (Threat Events):** Εδώ το NIST ξεχωρίζει παρέχοντας λίστες που βασίζονται σε Τακτικές, Τεχνικές και Διαδικασίες. Περιγράφει συγκεκριμένα σενάρια επίθεσης (π.χ. Phishing, SQL Injection,

Social Engineering) και μη εχθρικά συμβάντα, επιτρέποντας στον οργανισμό να εντοπίσει ακριβώς πώς μπορεί να εκδηλωθεί μια απειλή [120].

3. **Ευπάθειες και Προδιαθέτουσες Συνθήκες (Vulnerabilities & Predisposing Conditions):** Παρέχει καταλόγους ευπαθειών, αλλά εισάγει και την έννοια των «προδιαθετουσών συνθηκών». Αυτές είναι συνθήκες που υπάρχουν στον οργανισμό (π.χ. τοποθεσία σε περιοχή πλημμυρών ή χρήση stand-alone συστημάτων) οι οποίες αυξάνουν ή μειώνουν την πιθανότητα να συμβεί ένα κακό γεγονός [121].

Στρατηγική Εφαρμογής: Η στρατηγική του NIST είναι η «προσαρμογή». Ο οργανισμός καλείται να πάρει αυτές τις έτοιμες λίστες και να αφαιρέσει ό,τι δεν ταιριάζει (π.χ. αν δεν έχει αντίπαλο με συγκεκριμένες ικανότητες) ή να τις εμπλουτίσει με περισσότερες λεπτομέρειες [122].

3.5 Πόροι και Εφαρμογή

3.5.1 Πολυπλοκότητα υλοποίησης

Η μεθοδολογία του NIST χαρακτηρίζεται από υψηλή πολυπλοκότητα υλοποίησης λόγω της έκτασης, της λεπτομέρειας και της διασύνδεσης των εγγράφων της. Η εφαρμογή της δεν περιορίζεται σε ένα μόνο τμήμα, αλλά απαιτεί την εμπλοκή ολόκληρου του οργανισμού, από την ανώτατη διοίκηση (Tier 1) έως τους διαχειριστές συστημάτων (Tier 3) [123].

Συγκεκριμένα:

- **Απαίτηση Εξειδίκευσης:** Η διαδικασία δεν μπορεί να εκτελεστεί από ανειδίκευτο προσωπικό. Απαιτείται η συμμετοχή επαγγελματιών διαχείρισης κινδύνου με εξειδικευμένες γνώσεις, καθώς και ατόμων με τεχνική εμπειρογνωμοσύνη για την αξιολόγηση των συστημάτων [124]. Το NIST ορίζει συγκεκριμένους ρόλους όπως «Risk Executive», «Authorizing Official» και «Security Control Assessor», οι οποίοι απαιτούν υψηλό επίπεδο κατάρτισης [125].
- **Πολυπλοκότητα Διαδικασίας:** Η ανάγκη για συντονισμό μεταξύ τριών επιπέδων (Οργανισμός, Επιχειρησιακές Διαδικασίες, Συστήματα) και η

απαίτηση για αμφίδρομη ροή πληροφοριών αυξάνει τη διοικητική πολυπλοκότητα [126].

- **Διαχείριση Δεδομένων:** Ο όγκος των δεδομένων που παράγονται (απειλές, ευπάθειες, αποτελέσματα ελέγχων) είναι μεγάλος και συχνά απαιτεί αυτοματοποιημένα εργαλεία για τη διαχείρισή του, ειδικά στο επίπεδο της συνεχούς παρακολούθησης [127].

Ωστόσο, η ύπαρξη έτοιμων προτύπων (όπως οι κατάλογοι απειλών) μειώνει τον χρόνο που απαιτείται για την αρχική σχεδίαση της μεθοδολογίας, σε σχέση με το ISO που απαιτεί σχεδιασμό από το μηδέν.

3.5.2 Απαιτούμενοι πόροι (κόστος εφαρμογής)

Η εφαρμογή της μεθοδολογίας NIST απαιτεί σημαντική επένδυση πόρων, η οποία εστιάζεται κυρίως στη δέσμευση ανθρώπινου δυναμικού και στη διαχείριση της εκτενούς τεκμηρίωσης. Αν και τα πρότυπα διατίθενται δωρεάν, το λειτουργικό κόστος εφαρμογής τους είναι υψηλό.

α) Δέσμευση Ανθρώπινου Δυναμικού: Η διαδικασία απαιτεί τη συμμετοχή πολλών διαφορετικών ρόλων σε όλα τα επίπεδα της ιεραρχίας. Απαιτείται χρόνος από την ανώτατη διοίκηση (Heads of Agencies, Chief Executive Officers) για τον καθορισμό της στρατηγικής και της ανοχής στον κίνδυνο [128]. Επιπλέον, απαιτείται η ενεργή εμπλοκή εξειδικευμένων ρόλων όπως ο «Risk Executive», οι «Authorizing Officials» και οι «Security Control Assessors», οι οποίοι φέρουν την ευθύνη για τη λήψη αποφάσεων και την αξιολόγηση των ελέγχων [129].

β) Τεκμηρίωση και Γραφειοκρατία: Το NIST επιβάλλει αυστηρές απαιτήσεις τεκμηρίωσης. Κάθε βήμα της διαδικασίας πρέπει να καταγράφεται λεπτομερώς. Ειδικότερα, η διαδικασία αξιολόγησης παράγει εκτενείς αναφορές που πρέπει να περιλαμβάνουν την περιγραφή του σκοπού, του εύρους, των υποθέσεων, των περιορισμών, των μοντέλων που χρησιμοποιήθηκαν και των αποτελεσμάτων [130]. Η ανάγκη για τήρηση αρχείων για κάθε έλεγχο ασφαλείας αυξάνει σημαντικά τον διοικητικό φόρτο.

γ) Συνεχής Παρακολούθηση (Continuous Monitoring): Σε αντίθεση με μια εφάπαξ αξιολόγηση, το NIST απαιτεί συνεχή παρακολούθηση. Αυτό δεσμεύει μόνιμους πόρους για την επαλήθευση της συμμόρφωσης και τον έλεγχο της αποτελεσματικότητας των μέτρων σε βάθος χρόνου [131]. Για να μειωθεί αυτό το

κόστος, το πρότυπο ενθαρρύνει τη χρήση αυτοματοποιημένων εργαλείων, όπου αυτό είναι εφικτό, καθώς η χειροκίνητη παρακολούθηση είναι χρονοβόρα και ακριβή [132].

4. Συγκριτική Αξιολόγηση και Συμπεράσματα

4.1 Συγκεντρωτικός Πίνακας Κριτηρίων

Στον πίνακα που ακολουθεί παρουσιάζεται η συγκριτική επισκόπηση του προτύπου ISO/IEC 27005:2022 και των οδηγιών NIST SP 800-30 Rev.1 και SP 800-39, βάσει των τεσσάρων θεματικών αξόνων που ορίστηκαν στη μεθοδολογία της εργασίας.

Κριτήρια Σύγκρισης	ISO 27005	NIST SP 800-30 rev.1 και SP 800-39
Ταυτότητα και Προέλευση		
Φορέας Έκδοσης	Διεθνής Οργανισμός Τυποποίησης (ISO) και IEC.	Εθνικό Ινστιτούτο Προτύπων και Τεχνολογίας ΗΠΑ (NIST)
Τρέχουσα Έκδοση	Οκτώβριος 2022 (4 ^η έκδοση)	SP 800-39: Μάρτιος 2011 και SP 800-30 Rev.1: Σεπτέμβριος 2012
Νομική Φύση	Εθελοντικό Διεθνές Πρότυπο (Guidance)	Υποχρεωτικό για Ομοσπονδιακές υπηρεσίες ΗΠΑ, εθελοντικό για ιδιώτες
Γεωγραφική Εμβέλεια	Παγκόσμια (Worldwide standardization)	Τυπικά ΗΠΑ, πρακτικά παγκόσμια με πρόθεση εναρμόνισης με ISO
Κόστος Πρόσβασης	Επί πληρωμή (Πνευματικά δικαιώματα).	Δωρεάν (Έργο Κυβέρνησης ΗΠΑ Δεν έχει πνευματικά δικαιώματα).
Σκοπός και Αρχιτεκτονική		
Επίπεδα Εστίασης	Επιχειρησιακά περιουσιακά στοιχεία: Επιχειρησιακές διαδικασίες και πληροφορίες Υποστηρικτικά περιουσιακά στοιχεία: Υλικό, λογισμικό, δίκτυα, προσωπικό	Τρία Ιεραρχικά Επίπεδα: 1. Οργανισμός 2. Επιχειρησιακές Διαδικασίες 3. Πληροφοριακά Συστήματα
Δομή Εγγράφων	Ενιαίο έγγραφο καθοδήγησης	Αρθρωτή δομή (Το SP 800-39 για στρατηγική Το SP 800-30 για αξιολόγηση)

Κύκλος Διαχείρισης	Διαδικασία 6 Βημάτων (βάσει ISO 31000): 1. Καθορισμός πλαισίου 2. Αξιολόγηση 3. Αντιμετώπιση 4. Αποδοχή 5. Επικοινωνία 6. Παρακολούθηση Χαρακτηριστικό: Εκτελείται σε δύο κύκλους Στρατηγικό και Επιχειρησιακό	Επαναληπτικός κύκλος 4 αλληλένδετων βημάτων: 1. Πλαισίωση 2. Αξιολόγηση 3. Ανταπόκριση 4. Παρακολούθηση
Μεθοδολογία Αξιολόγησης Κινδύνου		
Προσέγγιση Αξιολόγησης	Βάσει Συμβάντων: Στρατηγικά σενάρια ή Βάσει Περιουσιακών Στοιχείων: Επιχειρησιακά σενάρια	Τρεις Προσεγγίσεις Αξιολόγησης: 1. Ποιοτική 2. Ποσοτική 3. Ημι-ποσοτική
Ευελιξία Μεθοδολογίας	Λειτουργεί ως μη-συνταγογραφικό πρότυπο και επιτρέπει στον κάθε οργανισμό να επιλέξει ή να αναπτύξει εξ ολοκλήρου τη δική του μέθοδο. Τα παραδείγματα δεν είναι δεσμευτικά και οι κλίμακες ορίζονται από τον εκάστοτε οργανισμό.	Προσφέρει προσέγγιση «έτοιμης λύσης», παρέχοντας πλήρη υποδείγματα ως σημείο εκκίνησης. Η χρήση τους είναι προαιρετική και πλήρως προσαρμόσιμη στις ανάγκες του εκάστοτε οργανισμού
Υπολογισμός Ρίσκου	Ελεύθερος καθορισμός. Συνήθως: Πιθανότητα Χ Συνέπεια με δυνατότητα συμπερίληψης της αξίας του περιουσιακού στοιχείου	Χρήση πίνακα κινδύνου με προκαθορισμένες κλίμακες 5 επιπέδων (Very Low-Very High) και υποχρεωτική καταγραφή της αβεβαιότητας
Λίστες Απειλών/Ευπαθειών	Ενδεικτικοί κατάλογοι με παραδείγματα τυπικών απειλών και ευπαθειών προς <u>βοήθεια</u>	Λίστες συμβάντων βάσει τακτικών και τεχνικών. Προσαρμογή των λιστών βάσει οργανισμού
Πόροι και Εφαρμογή		

Πολυπλοκότητα Υλοποίησης	Υψηλή προσπάθεια στην καθιέρωση πλαισίου. Λόγω έλλειψης έτοιμων λύσεων, ο οργανισμός ορίζει μόνος του κριτήρια και μεθόδους. Απαιτείται εξειδικευμένη γνώση και περιοδική εκπαίδευση αναλυτών για μείωση της υποκειμενικότητας	Υψηλή διοικητική και δομική πολυπλοκότητα. Απαιτεί συντονισμό 3 επιπέδων και εμπλοκή εξειδικευμένων ρόλων. Για τη διαχείριση μεγάλου όγκου δεδομένων συστήνονται αυτοματοποιημένα εργαλεία. Ύπαρξη έτοιμων προτύπων για ταχύτερο, αρχικό σχεδιασμό
Απαιτήσεις Πόρων	Κυρίως λειτουργικό κόστος: • Συντονισμό με τους οικονομικούς κύκλους • Δέσμευση χρόνου για συνεντεύξεις και ομαδικές αξιολογήσεις	Υψηλό λειτουργικό κόστος: • Δέσμευση εξειδικευμένων ρόλων • Μόνιμους πόρους για συνεχή παρακολούθηση • Αυστηρή τήρηση αρχείων

4.2 Συμπεράσματα Θεωρητικής Σύγκρισης

Η συγκριτική επισκόπηση των δύο πλαισίων αναδεικνύει ότι η επιλογή μεταξύ του προτύπου ISO 27005 και της σειράς οδηγιών NIST SP 800 δεν αποτελεί απλώς ένα τεχνικό δίλημμα, αλλά μια στρατηγική απόφαση που επηρεάζει τη διοικητική κουλτούρα του οργανισμού. Η ειδοποιός διαφορά εντοπίζεται πρωτίστως στην προσέγγιση υλοποίησης, όπου συγκρούονται δύο διαφορετικές φιλοσοφίες.

Το ISO 27005, λειτουργώντας ως ένας οδηγός υψηλού επιπέδου, προσφέρει στον οργανισμό την ελευθερία να σχεδιάσει τη μεθοδολογία από το μηδέν, συνδέοντας τα περιουσιακά στοιχεία με τους επιχειρησιακούς στόχους. Αυτή η ευελιξία, ωστόσο, μεταθέτει το βάρος της προσπάθειας στην αρχική φάση καθιέρωσης του πλαισίου, καθώς απαιτεί από τη διοίκηση να ορίσει αυτόνομα τα κριτήρια και τις κλίμακες. Στον αντίποδα, το NIST προσφέρει μια πιο πρακτική αφετηρία, παρέχοντας έτοιμες ταξινομίες, υποδείγματα και κλίμακες, λύνοντας το πρόβλημα της αρχικής σχεδίασης. Το τίμημα αυτής της διευκόλυνσης είναι η αυξημένη διοικητική πολυπλοκότητα, καθώς η εφαρμογή του απαιτεί τον συντονισμό τριών ιεραρχικών επιπέδων (Tiers) και τη δέσμευση εξειδικευμένων ρόλων, καθιστώντας το μια πιο «βαριά» δομικά διαδικασία.

Πέραν της δομής, διακριτή είναι και η διαφορά στο βάθος της τεχνικής ανάλυσης. Ενώ το ISO εστιάζει περισσότερο στη στρατηγική ευθυγράμμιση και τη σύνδεση με τους οικονομικούς κύκλους, το NIST εμβαθύνει σε τεχνικές λεπτομέρειες, εισάγοντας έννοιες όπως η χρήση διανυσμάτων για την αναπαράσταση του κινδύνου, η υποχρεωτική καταγραφή της αβεβαιότητας και η ανάλυση βάσει τακτικών και τεχνικών (TTPs). Αυτή η τεχνική αρτιότητα, σε συνδυασμό με το γεγονός ότι διατίθεται δωρεάν ως δημόσιο αγαθό -σε αντίθεση με τον εμπορικό χαρακτήρα του ISO- το καθιστά ελκυστικό για οργανισμούς που αναζητούν άμεση τεχνογνωσία και αυστηρή μεθοδολογία.

Συμπερασματικά, τα δύο πρότυπα δεν πρέπει να αντιμετωπίζονται ως αμοιβαία αποκλειόμενα, αλλά συχνά ως συμπληρωματικά. Στην πράξη, ένας οργανισμός μπορεί να επιδιώκει την πιστοποίηση κατά ISO 27001 για λόγους κανονιστικής συμμόρφωσης και εξωστρέφειας, χρησιμοποιώντας παράλληλα το πλούσιο υλικό του NIST (όπως τους καταλόγους απειλών) ως τον λειτουργικό μηχανισμό της αξιολόγησης. Συνεπώς, το ISO 27005 κρίνεται ιδανικό για όσους προτάσσουν την ευελιξία και τη διεθνή αναγνώριση, ενώ το NIST αποτελεί τη βέλτιστη επιλογή για οργανισμούς που απαιτούν λεπτομερή καθοδήγηση, έτοιμα εργαλεία και αυστηρή τεχνική τεκμηρίωση, καθώς και για εκείνους που υπόκεινται σε κανονιστική υποχρέωση συμμόρφωσης με τα ομοσπονδιακά πρότυπα των ΗΠΑ.

5. Παρουσίαση Εργαλείων Λογισμικού

5.1 Εισαγωγή

Πριν την τεχνική παρουσίαση και αξιολόγηση των εξειδικευμένων εργαλείων λογισμικού (GRC Tools), κρίνεται σκόπιμο να αποτυπωθεί η πρακτική πραγματικότητα της αγοράς. Στο πλαίσιο της παρούσας μελέτης και κατόπιν προσωπικής επικοινωνίας με εν ενεργεία Υπεύθυνο Ασφάλειας Πληροφοριών (Chief Information Security Officer-CISO) στην Αθήνα, αναδείχθηκε μια σημαντική απόκλιση μεταξύ της θεωρητικής διαθεσιμότητας εργαλείων και της πρακτικής εφαρμογής τους.

Συγκεκριμένα, επισημάνθηκε ότι η υιοθέτηση εξειδικευμένων πλατφορμών διαχείρισης κινδύνου δεν αποτελεί τον κανόνα για την πλειονότητα των επιχειρήσεων. Με εξαίρεση τους μεγάλους πολυεθνικούς οργανισμούς και τις κορυφαίες ελεγκτικές εταιρείες, οι περισσότερες εταιρείες τείνουν να ακολουθούν δύο εναλλακτικές πρακτικές:

1. **Εκτεταμένη χρήση του Microsoft Excel:** Η κυρίαρχη τάση στις μικρομεσαίες επιχειρήσεις είναι η χρήση λογισμικών γενικής χρήσης και κυρίως του Microsoft Excel. Οι οργανισμοί αυτοί βασίζονται σε προσαρμοσμένα λογιστικά φύλλα και εσωτερικές διαδικασίες για την καταγραφή και παρακολούθηση των κινδύνων. Η επιλογή αυτή υπαγορεύεται από την ανάγκη για ευελιξία, την άμεση εξοικείωση του προσωπικού με το εργαλείο και την αποφυγή κόστους αδειοδότησης νέων εφαρμογών.
2. **Εξωτερική Ανάθεση (Outsourcing):** Παράλληλα, παρατηρείται συχνά η ανάθεση των ελέγχων ασφαλείας σε εξωτερικούς συνεργάτες. Μέσω αυτής της πρακτικής, οι εταιρείες αποφεύγουν την πολυπλοκότητα της εσωτερικής διαχείρισης εργαλείων, καθώς λαμβάνουν έτοιμα τα αποτελέσματα των ελέγχων, μεταθέτοντας την ευθύνη της μεθοδολογικής και τεχνικής υποστήριξης στον εξωτερικό πάροχο.

Υπό αυτό το πρίσμα, η εξέταση των εργαλείων (SimpleRisk, Monarc, Verinice, EAR/PILAR) που ακολουθεί, πραγματοποιείται βάσει ενός νέου, διακριτού πλαισίου αξιολόγησης. Στόχος της παρούσας ενότητας είναι η αντικειμενική αποτίμηση των χαρακτηριστικών και των δυνατοτήτων τους, μέσα από την εφαρμογή συγκεκριμένων

κριτηρίων που ορίστηκαν για τις ανάγκες της παρούσας μελέτης. Προκειμένου η σύγκριση να είναι ολιστική, τα κριτήρια ταξινομήθηκαν σε τρεις διακριτούς άξονες:

1. Τεχνική Ταυτότητα και Αδειοδότηση:

Ο πρώτος άξονας αφορά τη διαθεσιμότητα και τις τεχνικές απαιτήσεις της εφαρμογής, στοιχεία καθοριστικά για τη βιωσιμότητα της λύσης σε έναν οργανισμό:

- **Μοντέλο Αδειοδότησης:** Εξετάζεται αν το λογισμικό είναι Ανοικτού Κώδικα (Open Source), Εμπορικό (Commercial) ή προσφέρει δωρεάν έκδοση με περιορισμούς (Trial).
- **Εύρος Δωρεάν Διάθεσης:** Αξιολογείται αν η δωρεάν έκδοση είναι πλήρης, δοκιμαστική (Beta/Demo) ή χρονικά περιορισμένη, καθώς και αν επιτρέπει την παραγωγική χρήση χωρίς κρυφά κόστη.
- **Αρχιτεκτονική και Απαιτήσεις:** Διαχωρισμός μεταξύ διαδικτυακών εφαρμογών (Web-based), που ευνοούν τη συνεργασία πολλών χρηστών και αυτόνομων εφαρμογών γραφείου (Desktop/Standalone). Παράλληλα, εξετάζεται η πολυπλοκότητα της εγκατάστασης και οι απαιτήσεις σε υπολογιστικούς πόρους.

2. Λειτουργικότητα Διαχείρισης Κινδύνου:

Ο δεύτερος άξονας εξετάζει την ουσία της διαδικασίας, δηλαδή το κατά πόσο το εργαλείο μπορεί να υποστηρίξει μια ολοκληρωμένη μελέτη επικινδυνότητας:

- **Διαχείριση Περιουσιακών Στοιχείων:** Η δυνατότητα μαζικής εισαγωγής, κατηγοριοποίησης και αποτίμησης των περιουσιακών στοιχείων του οργανισμού.
- **Προεγκατεστημένες Βιβλιοθήκες:** Το κρισιμότερο ίσως κριτήριο λειτουργικότητας. Εξετάζεται αν το εργαλείο παρέχει έτοιμους καταλόγους απειλών, ευπαθειών και μέτρων ασφαλείας (βάσει ISO 27001/27002 ή NIST SP 800-53), απαλλάσσοντας τον χρήστη από τη χειροκίνητη καταχώρηση.
- **Μηχανισμός Υπολογισμού:** Η δυνατότητα παραμετροποίησης του τρόπου υπολογισμού του ρίσκου (π.χ. δημιουργία custom Risk Matrix) ώστε να ταιριάζει με τη μεθοδολογία του οργανισμού.

- **Αναφορές:** Η δυνατότητα εξαγωγής εποπτικών πινάκων (Dashboards) και τελικών αναφορών (σε μορφή PDF/Excel) για την παρουσίαση στη διοίκηση.

3. Εμπειρία Χρήστη:

- **Περιβάλλον Διεπαφής (Interface):** Αξιολογείται η εργονομία, η ευκολία πλοήγησης και η καμπύλη εκμάθησης του εργαλείου, καθώς ένα δύσχρηστο περιβάλλον αποτελεί συχνά αποτρεπτικό παράγοντα για την υιοθέτησή του έναντι των απλούστερων λογιστικών φύλλων.

5.2 Εργαλεία

5.2.1 SimpleRisk

5.2.1.1 Τεχνική Ταυτότητα και Αδειοδότηση

Σε αυτή την ενότητα αναλύονται τα τεχνικά χαρακτηριστικά και το πλαίσιο διάθεσης του SimpleRisk, στοιχεία που καθορίζουν τη δυνατότητα πρόσβασης και χρήσης του από έναν οργανισμό.

- **Μοντέλο Αδειοδότησης:** Το SimpleRisk ακολουθεί το μοντέλο «Freemium». Η βασική εγκατάσταση του εργαλείου (SimpleRisk Core) διατίθεται δωρεάν μέσω της ιστοσελίδας της εταιρείας, επιτρέποντας στον χρήστη να κατεβάσει και να εγκαταστήσει τον πυρήνα της εφαρμογής χωρίς κόστος. Ωστόσο, οποιαδήποτε επιπλέον λειτουργικότητα απαιτηθεί δεν περιλαμβάνεται στη δωρεάν έκδοση και πρέπει να αγοραστεί ξεχωριστά από τον εκάστοτε πελάτη [133].
- **Εύρος Δωρεάν Διάθεσης:** Κατά τη διαδικασία λήψης του λογισμικού για τοπική εγκατάσταση, διαπιστώθηκε ένας σημαντικός περιορισμός προσβασιμότητας. Η κατασκευάστρια εταιρεία εφαρμόζει αυστηρή πολιτική ελέγχου, απαγορεύοντας τη λήψη της εφαρμογής σε ιδιώτες (φυσικά πρόσωπα). Συγκεκριμένα, το σύστημα δεν αποδέχεται διευθύνσεις από δημόσιους παρόχους ηλεκτρονικού ταχυδρομείου (όπως Outlook, Gmail, Yahoo), επιτρέποντας τη λήψη του αρχείου

εγκατάστασης αποκλειστικά σε εταιρικό προσωπικό με επαγγελματικό domain [134].

Επιλογές Αξιολόγησης και Δοκιμής: Για τους χρήστες που επιθυμούν να αξιολογήσουν το λογισμικό πριν προχωρήσουν σε εγκατάσταση ή αγορά, η εταιρεία παρέχει τρεις διακριτές επιλογές, με διαφορετικούς βαθμούς ελευθερίας [135]:

1. **Δωρεάν Δοκιμή 30 Ημερών (30-day Free Trial):** Πρόκειται για μια πλήρως φιλοξενούμενη (Hosted) έκδοση που περιλαμβάνει όλες τις επί πληρωμή παροχές που προσφέρουν. Ωστόσο, η επιλογή αυτή διατίθεται αυστηρά για επιχειρησιακή χρήση και απαιτεί εταιρική εγγραφή.
 2. **Live Demonstration:** Αφορά μια ζωντανή παρουσίαση των δυνατοτήτων του εργαλείου από εκπρόσωπο της εταιρείας. Η επιλογή αυτή δεν είναι άμεση (on-demand), καθώς απαιτεί από τον ενδιαφερόμενο πελάτη να επικοινωνήσει με το τμήμα πωλήσεων για τον προγραμματισμό της συνεδρίας.
 3. **SimpleRisk Sandbox:** Αυτή είναι η επιλογή που χρησιμοποιήθηκε για τις ανάγκες της παρούσας μελέτης. Πρόκειται για μια online προσομοίωση της πλήρους λειτουργικότητας της εφαρμογής. Μέσω του Sandbox, παρέχεται άμεση πρόσβαση στο περιβάλλον εργασίας χωρίς την ανάγκη εγκατάστασης. Αν και αποτελεί μια πλήρη απεικόνιση της εφαρμογής, υπόκειται σε λειτουργικούς περιορισμούς, οι οποίοι όμως δεν εμποδίζουν την αξιολόγηση των διαδικασιών διαχείρισης κινδύνου.
- **Αρχιτεκτονική και Απαιτήσεις:** Το SimpleRisk είναι μια διαδικτυακή εφαρμογή (Web-based), επιτρέποντας την ταυτόχρονη πρόσβαση πολλών χρηστών μέσω browser. Οι απαιτήσεις συστήματος είναι ιδιαίτερα χαμηλές, καθώς για την εγκατάστασή του απαιτείται ένας τυπικός εξυπηρετητής με ελάχιστα χαρακτηριστικά: επεξεργαστή 2 πυρήνων (CPU), μνήμη RAM 2 GB και αποθηκευτικό χώρο 20 GB [136].

5.2.1.2 Λειτουργικότητα Διαχείρισης Κινδύνου

Μέσω της εξέτασης του περιβάλλοντος προσομοίωσης (Sandbox), αξιολογήθηκε η πληρότητα του εργαλείου στους τέσσερις βασικούς άξονες λειτουργικότητας:

- **Διαχείριση Περιουσιακών Στοιχείων:** Το εργαλείο διαθέτει ισχυρούς μηχανισμούς για την απογραφή και αποτίμηση των περιουσιακών στοιχείων. Όπως αποτυπώνεται στην επιλογή «**Manage Assets**», κάθε περιουσιακό στοιχείο συνοδεύεται από πεδίο χρηματικής αποτίμησης (Asset Valuation, π.χ. «\$200,000 to \$300,000»), επιτρέποντας την οικονομική στάθμιση του κινδύνου. Επιπλέον, το SimpleRisk απαντά στην ανάγκη μαζικής εισαγωγής μέσω της λειτουργίας «**Automated Discovery**», η οποία επιτρέπει τη σάρωση διευθύνσεων IP (IP Range Scan) για τον αυτόματο εντοπισμό και καταχώρηση συσκευών στο μητρώο, μειώνοντας δραστικά τον φόρτο της χειροκίνητης εισαγωγής [137].

Actions	Asset Name	IP Address	Asset Valuation	Site/Location	Team	Asset Details	Mapped Controls	Associated Risks
	Asset N°	IP Addr	Asset Val	Site/Location	Team	Asset D	Mapped Controls	Associated Risks
 	backuppcc		\$200,001 to \$300,000		IT Systems Management, Unix	serveur de backup de fichiers	1.2.3 Controle des accès, DCH-23.3: Release, EMB-06: Prevent Alterations, Encryption sensitive data	[2020]Teste, [2037]Database, [2045]database, [2056]Shai-hulud, [1383] Health System Web Server, [2025]Утечка конфиденциальных данных клиентов, [2026]Утечка данных через уязвимость в веб-приложении, [2054]Утечка данных через уязвимость в веб-приложении, [1335]Attackers can exfiltrate data from our networks compromising the privacy and integrity of sensitive information, [1186]An attacker may have a greater impact, cause more damage, infect more systems, and exfiltrate more sensitive data due to a poor incident response plan
 	gitlab		\$200,001 to \$300,000		IT Systems Management, Unix	serveur de code source	1.2.3 Controle des accès, DCH-23.3: Release, EMB-06: Prevent Alterations, Encryption sensitive data	[2022]Teste, [2023]Teste, [2055]test01 Qiong FAN

Automated Discovery

Discover all live IP addresses in the entered IP range. Live IP addresses will be added to the asset list. Acceptable formats:

- 192.168.0.1
- 192.168.0.1-192.168.0.255

IP Range:

Search

- **Προεγκατεστημένες Βιβλιοθήκες:** Το λογισμικό παρέχει έτοιμες βιβλιοθήκες που καλύπτουν τα διεθνή πρότυπα. Στην οθόνη **«Define Control Frameworks»**, εντοπίστηκαν ενεργοποιημένα πλαίσια όπως το ISO 27001 και το NIST 800-82, ενώ στην ενότητα **«Self Assessments»** υπάρχουν έτοιμα ερωτηματολόγια για το PCI DSS 3.2 που αφορά την ασφάλεια συναλλαγών με κάρτες και το HIPAA που διέπει την ασφάλεια των ιατρικών δεδομένων. Κατά την εισαγωγή κινδύνου (Submit Risk), ο χρήστης έχει στη διάθεσή του το πεδίο **«Threat Mapping»**, που συνδέει το συμβάν με τυποποιημένες απειλές (π.χ.

Framework Name	Framework Description	Actions
ISO 27001	ISO 27001 is an international standard that provides a framework for an Information Security Management System (ISMS) to manage the security of information assets, ensuring their confidentiality, integrity, and availability. It requires organizations to implement a risk-based approach, including a systematic risk assessment and the application of security controls to protect data from threats. The framework promotes a continuous improvement cycle for information security and is the only certifiable international standard for information security.	
NIST 800-82		
Test		

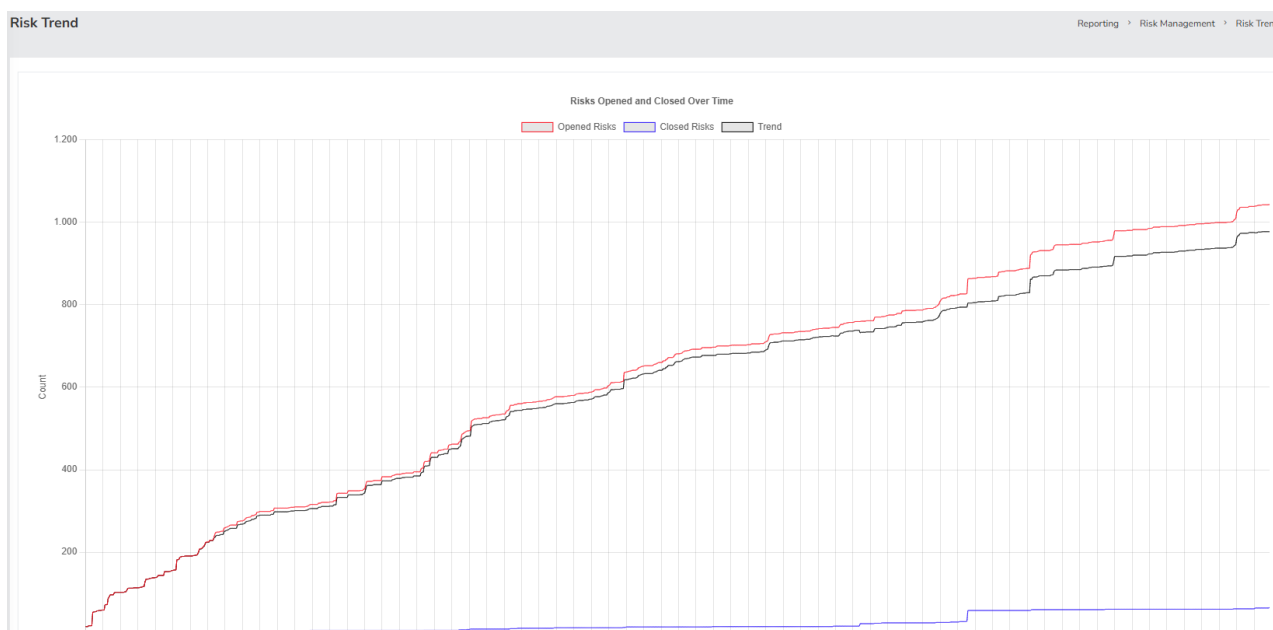
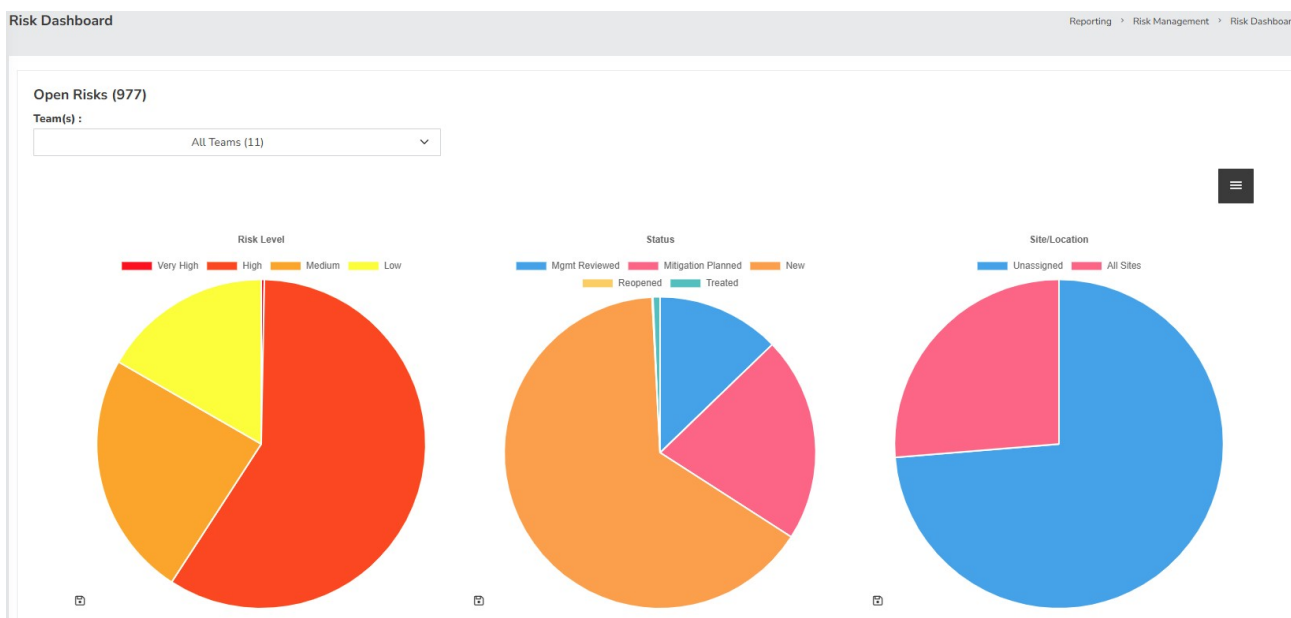
«Hacking & Other Cybersecurity Crimes»), καθώς και το πεδίο **«Control δRegulation»** για άμεση συσχέτιση με κανονιστικές απαιτήσεις [137].

- **Μηχανισμός Υπολογισμού:** Η πλατφόρμα υποστηρίζει δυναμικό υπολογισμό και παρακολούθηση της εξέλιξης του κινδύνου. Στην οθόνη **«Plan Mitigation»**, εμφανίζονται διακριτά ο Εγγενής Κίνδυνος (Inherent Risk) και ο Υπολειπόμενος Κίνδυνος (Residual Risk) με ξεκάθαρες αριθμητικές τιμές. Παράλληλα, το σύστημα προσφέρει πολλαπλές μεθοδολογίες βαθμολόγησης

ID	Status	Subject	Inherent Risk (Current)	Submission Date	Date Closed	Risk Source	Team	Owner	Risk Scoring Method	Residual Risk (Current)	Project	Mitigation Planned	Plan Status
1207	New	DDoS Attacks	10	03/09/2023 1:17 PM CST		External			Contributing Risk	10		No	
1210	New	Attackers can scan for remotely accessible network services that are vulnerable to exploitation	10	12/16/2022 7:30 PM CST					Custom	10		No	
1211	New	kygfr	10	03/19/2023 6:25 AM CDT					Classic	10		No	
1222	New	Attackers can exfiltrate data from our networks compromising the privacy and integrity of sensitive information	10	12/16/2022 7:30 PM CST					Custom	10		No	
1223	New	Attackers can gain wireless access and bypass our security perimeters in order to steal data	10	12/16/2022 7:30 PM CST					Custom	10		No	

μέσω του πεδίου «**Risk Scoring Method**» (επιλογές όπως Classic, Custom, Contributing Risk), επιτρέποντας στον οργανισμό να προσαρμόσει τον αλγόριθμο στις δικές του ανάγκες [137].

- **Αναφορές:** Η δυνατότητα εξαγωγής συμπερασμάτων ενισχύεται από προηγμένα εργαλεία οπτικοποίησης. Το «**Risk Dashboard**» παρέχει γραφήματα πίτας για την κατανομή των κινδύνων ανά επίπεδο (High, Medium, Low) και ανά τοποθεσία (Site/Location). Ιδιαίτερα σημαντική είναι η αναφορά «**Risk Trend**», η οποία εμφανίζει σε γραμμικό γράφημα την ιστορική εξέλιξη των ανοικτών και κλειστών κινδύνων σε βάθος χρόνου, προσφέροντας στη διοίκηση μια ξεκάθαρη εικόνα για την τάση βελτίωσης ή επιδείνωσης της ασφάλειας του οργανισμού [137].



5.2.1.3 Εμπειρία Χρήστη

Το περιβάλλον διεπαφής (interface) του SimpleRisk διακρίνεται για τη σύγχρονη και προσεγμένη αισθητική του, η οποία απέχει σημαντικά από την ψυχρή εικόνα των παραδοσιακών λογιστικών φύλλων. Η εφαρμογή αξιοποιεί έντονα οπτικά στοιχεία, και ευανάγνωστα γραφήματα στο κεντρικό ταμπλό, προσφέροντας στον χρήστη μια άμεση και ευχάριστη οπτική εποπτεία της κατάστασης ασφαλείας του οργανισμού. Η πλοήγηση βασίζεται σε μια σταθερή στήλη, η οποία οργανώνει τις λειτουργίες με σαφήνεια, ενώ η πρακτικότητα ενισχύεται από έξυπνους μηχανισμούς ροής εργασίας (workflow). Παρά την εργονομική του σχεδίαση, το εύρος των δυνατοτήτων του εργαλείου μπορεί αρχικά να ξενίσει ή να δυσκολέψει τον νέο χρήστη. Αυτό γίνεται ιδιαίτερα αντιληπτό στο μενού των Αναφορών (Reporting), όπου η πληθώρα των διαθέσιμων επιλογών -από απλά dashboards και γραφήματα τάσεων μέχρι σύνθετα εργαλεία οπτικοποίησης- δημιουργεί ένα πυκνό πληροφοριακό περιβάλλον. Η ύπαρξη τόσων πολλών εναλλακτικών, αν και αποδεικνύει την πληρότητα της εφαρμογής, αυξάνει την πολυπλοκότητα και απαιτεί χρόνο εξοικείωσης ώστε ο χρήστης να εντοπίσει ακριβώς αυτό που χρειάζεται χωρίς να χάνεται στις επιλογές. Ωστόσο, μόλις ξεπεραστεί αυτή η δυσκολία εκμάθησης, το SimpleRisk αποδεικνύεται μια εξαιρετικά ισχυρή και ποιοτική εφαρμογή, ικανή να καλύψει τις ανάγκες ακόμα και των πιο απαιτητικών οργανισμών [137].

5.2.2 Monarc

Το MONARC (Method for an Optimized Analysis of Risks by CASES) αποτελεί μια ιδιάζουσα περίπτωση στον χώρο των εργαλείων GRC, καθώς δεν προέρχεται από κάποια ιδιωτική εταιρεία λογισμικού, αλλά αναπτύχθηκε ως κρατική πρωτοβουλία. Συγκεκριμένα, δημιουργήθηκε από τον οργανισμό CASES (Cybersecurity Agency for the Security of the Economic Sector) του Λουξεμβούργου, ο οποίος πλέον υπάγεται στο Εθνικό Κέντρο Κυβερνοασφάλειας της χώρας (NC3-National Cybersecurity Competence Center) [154].

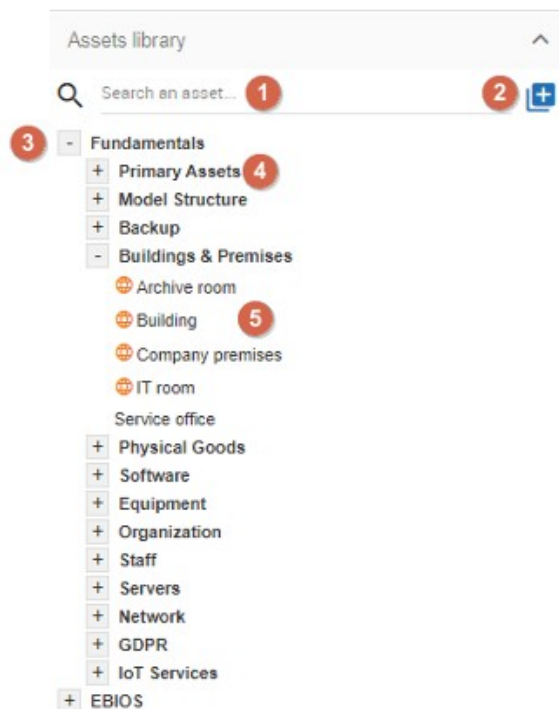
5.2.2.1 Τεχνική Ταυτότητα και Αδειοδότηση

- **Μοντέλο Αδειοδότησης:** Το λογισμικό είναι αυστηρά ανοικτού κώδικα (open source) και διατίθεται υπό την άδεια GNU Affero General Public License version 3 (AGPLv3). Η επιλογή αυτής της άδειας είναι στρατηγικής σημασίας, καθώς διασφαλίζει ότι το εργαλείο παραμένει ελεύθερο και ότι οποιαδήποτε τροποποίηση στον κώδικα, εάν αυτός διατεθεί μέσω δικτύου, πρέπει επίσης να δημοσιεύεται με την ίδια άδεια. Το MONARC αναπτύχθηκε ως «δημόσιο αγαθό» με στόχο την ενίσχυση της ασφάλειας των επιχειρήσεων, χωρίς κερδοσκοπικό χαρακτήρα [154].
- **Εύρος Δωρεάν Διάθεσης:** Λόγω της φύσης του έργου, δεν υπάρχει διαχωρισμός μεταξύ δωρεάν και εμπορικής έκδοσης. Ο χρήστης έχει πρόσβαση στο σύνολο των δυνατοτήτων του εργαλείου χωρίς κανέναν οικονομικό περιορισμό ή «κλειδωμένα» χαρακτηριστικά [154]. Για την εγκατάσταση του εργαλείου, προσφέρονται τρεις βασικές μέθοδοι που καλύπτουν διαφορετικές ανάγκες:
 1. **Προ-εγκατεστημένη εικονική μηχανή (OVA):** Για άμεση δοκιμή χωρίς πολύπλοκες ρυθμίσεις, μέσω λογισμικού προσομοίωσης (π.χ. VirtualBox) [155].
 2. **Docker Containers:** Η προτεινόμενη μέθοδος για παραγωγική λειτουργία, η οποία προσφέρει ευκολία στη διαχείριση και τις αναβαθμίσεις [156].
 3. **Λήψη Πηγαίου Κώδικα:** Δυνατότητα χειροκίνητης εγκατάστασης απευθείας από το GitHub για εξειδικευμένες παραμετροποιήσεις [156].
- **Αρχιτεκτονική και Απαιτήσεις:** Το MONARC είναι μια αμιγώς διαδικτυακή εφαρμογή, σχεδιασμένη για συνεργατική χρήση. Τεχνολογικά, το backend είναι αναπτυγμένο σε Python (Django framework) και το frontend σε JavaScript (AngularJS), ενώ χρησιμοποιεί MySQL/MariaDB ως βάση δεδομένων. Οι απαιτήσεις συστήματος για την εικονική μηχανή είναι μέτριες, καθώς απαιτούνται τουλάχιστον 4 GB μνήμης RAM και 20 GB ελεύθερου χώρου στον δίσκο [156].

5.2.2.2 Λειτουργικότητα Διαχείρισης Κινδύνου

Η καρδιά του MONARC είναι η δομημένη διαδικασία ανάλυσης κινδύνου, η οποία ακολουθεί πιστά τη μεθοδολογία του ISO/IEC 27005. Το εργαλείο καθοδηγεί τον χρήστη μέσω μιας ιεραρχικής προσέγγισης, επιτρέποντας τη λεπτομερή μοντελοποίηση του οργανισμού.

- **Διαχείριση Περιουσιακών Στοιχείων:** Η διαχείριση των περιουσιακών στοιχείων στο MONARC υλοποιείται μέσω μιας δυναμικής δενδρικής δομής (Asset Tree). Το σύστημα διαχωρίζει σαφώς τα περιουσιακά στοιχεία σε δύο κύριες κατηγορίες, ακολουθώντας τη λογική των εξαρτήσεων:
 - ο **Πρωτογενή Αγαθά (Primary Assets):** Περιλαμβάνουν τις επιχειρηματικές διαδικασίες και τις πληροφορίες που έχουν άμεση αξία για τον οργανισμό. Εδώ ορίζονται οι επιπτώσεις (Impacts) σε περίπτωση παραβίασης της εμπιστευτικότητας, ακεραιότητας ή διαθεσιμότητας [157].
 - ο **Υποστηρικτικά Αγαθά (Supporting Assets):** Περιλαμβάνουν το υλικό (hardware), το λογισμικό, το δίκτυο και το ανθρώπινο δυναμικό. Αυτά τα στοιχεία «κληρονομούν» την αξία από τα πρωτογενή αγαθά και αποτελούν τα σημεία όπου εφαρμόζονται οι απειλές και τα τρωτά σημεία [157].



1. Search area in order to quickly find an asset.
 2. Button for creating/importing assets (see [Create an Asset](#)).
 3. Categories level of the Library. There are usually two categories as follows:
 1. **Fundamentals**: Contains all default assets offered by NC3.
 2. **EBIOS**: Contains assets inspired by EBIOS. These are assets containing non-optimized risk models.
 4. Sub-categories level.
 5. Asset level: These are the assets that must be dragged and dropped to the Risk Analysis area.
- **Προεγκατεστημένες Βιβλιοθήκες**: Ένα από τα ισχυρότερα χαρακτηριστικά του MONARC είναι η ενσωματωμένη «βάση γνώσης» (Knowledge Base). Το εργαλείο δεν απαιτεί από τον χρήστη να εισάγει δεδομένα από το μηδέν, καθώς παρέχει:
 - ο **Πρότυπα Αντικείμενα (Object Libraries)**: Έτοιμες κατηγορίες περιουσιακών στοιχείων (π.χ. Servers, Laptops) με προκαθορισμένες ιδιότητες [158].
 - ο **Καταλόγους Απειλών και Τρωτοτήτων**: Κάθε τύπος παγίου συνδέεται αυτόματα με σχετικές απειλές και τρωτά σημεία, βασισμένα σε πρότυπα όπως το ISO 27005 και τις προδιαγραφές του οργανισμού CASES. Αυτό επιταχύνει τη διαδικασία της ανάλυσης και διασφαλίζει ότι δεν παραλείπονται κρίσιμοι κίνδυνοι [158].

Asset import center

Import method:

☐ By duplicating
 ☒ By merging

Only global assets can be imported by merge.

List of common MONARC assets

Q

Search an asset...

Name	Category	Asset type	Actions
Front Office	Model Structure	Container	
Specific software	Software	Software	
Specific software maintenance	Software	Software maintenance	
User workstations	Equipment	Desktop computer	

1. Table of available assets in the MONARC common Library.
2. **Action:** Initiate the import procedure for the corresponding asset.

- Μηχανισμός Υπολογισμού:** Ο υπολογισμός της επικινδυνότητας στο MONARC είναι ημι-ποσοτικός και βασίζεται σε πίνακες (Risk Matrices). Η διαδικασία ακολουθεί τα εξής βήματα:
 1. **Αξιολόγηση Επιπτώσεων:** Ορίζεται η επίπτωση στα πρωτογενή αγαθά βάσει κλίμακας (συνήθως 0-4) για τις παραμέτρους C-I-A (Confidentiality, Integrity, Availability).
 2. **Εκτίμηση Πιθανότητας:** Υπολογίζεται η πιθανότητα εμφάνισης της απειλής στα υποστηρικτικά αγαθά.
 3. **Υπολογισμός Κινδύνου:** Το εργαλείο υπολογίζει αυτόματα τον εγγενή κίνδυνο (Inherent Risk) πολλαπλασιάζοντας την επίπτωση με την πιθανότητα. Στη συνέχεια, λαμβάνοντας υπόψη τα υφιστάμενα μέτρα ασφαλείας, παράγει τον υπολειπόμενο κίνδυνο (Residual Risk), χρωματίζοντας τα αποτελέσματα βάσει του καθορισμένου ορίου αποδοχής κινδύνου (Risk Acceptance Threshold) [159].

46

Search an asset...

MyPrint [EN]

- + IoT
- Printing department
 - Printing operators
 - Back Office Rotary printing press
 - System administrator
 - Building
 - Network and Telecom
 - Rotary printing press
- Computer graphics department
 - Front Office
 - Back Office
- + GDPR legal obligations

Information risks

Operational risks

74 information risks

Risk threshold (on max CIA) ☒ ☐ ☐ ☐ ☐ Keywords

Asset	Impact			Threat		Vulnerability	
	C	I	A	Label	Prob.	Label	Existing c
Printing operators	1	2	3	Error in use	3	Users are not made aware of information security	The person in place doe He is retiring soon.
Printing operators	1	2	3	Error in use	3	No IT charter specifying the rules of use	No charter in place.

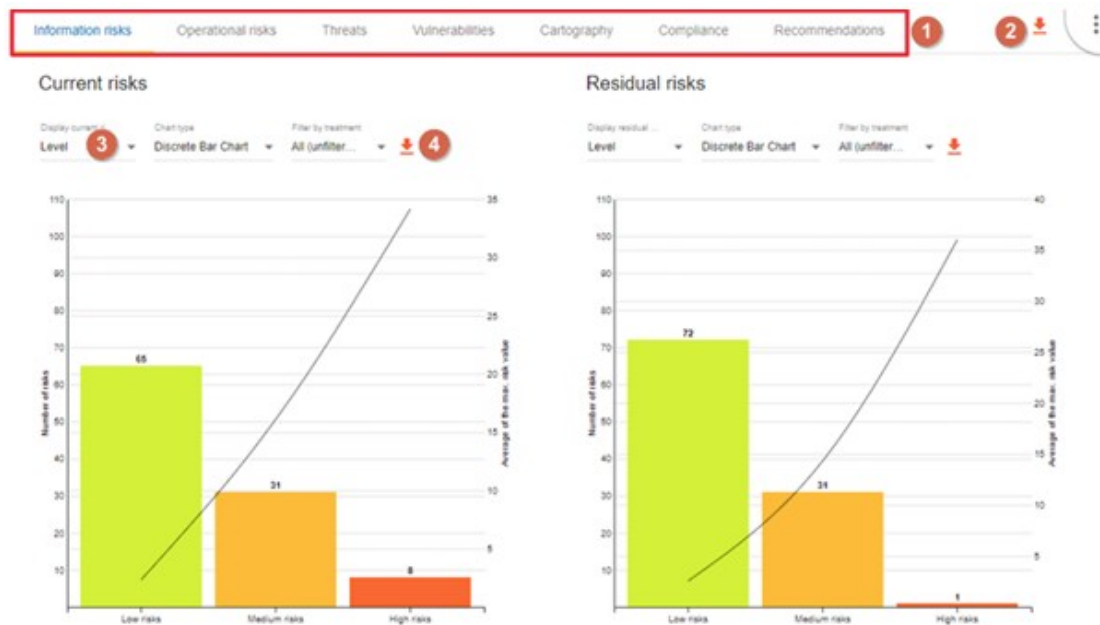
1. The information risk table is based on CIA^[1] criteria.
2. The operational risk table is based on ROLFP^[2] (see [Operational Risks](#))

Depending on your selection, the display risk table may change:

Selection	Information Risks	Operational Risks
Root of analysis	All risks of analysis	All risks of analysis
Primary Asset	Risks associated with its supporting assets	Risks associated with themselves
Supporting Asset	Risks associated with themselves	No risks

- **Αναφορές:** Το σύστημα παραγωγής αναφορών του MONARC είναι σχεδιασμένο για να καλύπτει τόσο τις τεχνικές όσο και τις διοικητικές απαιτήσεις. Μέσω του «Dashboard» και του μενού εξαγωγών, ο χρήστης μπορεί να λάβει:
 - ο **Πίνακα κινδύνων (Risk Table):** Μια αναλυτική απεικόνιση όλων των κινδύνων, ταξινομημένων κατά κρισιμότητα [160].
 - ο **Σχέδιο αντιμετώπισης (Risk Treatment Plan):** Αναφορά που περιλαμβάνει τα προτεινόμενα μέτρα, τους υπευθύνους υλοποίησης και το χρονοδιάγραμμα.

- ο **Δήλωση εφαρμογής (Statement of Applicability)**: Το εργαλείο παράγει αυτόματα το έγγραφο SoA, το οποίο αποτελεί προαπαιτούμενο



All the part of the dashboard have the same functionalities.

1. **Choose** the part on which a dashboard is required.
2. **Export** all the data in a XLSX document to make your own graph.
3. **Change** the paramaters of the selected chart.
4. **Export** the chart as PNG

για την πιστοποίηση κατά ISO 27001. Η λειτουργία αυτή βασίζεται στη δυναμική αντιστοίχιση των μέτρων αντιμετώπισης που επέλεξε ο χρήστης με τους πρότυπους ελέγχους, τεκμηριώνοντας ποιες ασφαλιστικές δικλίδες εφαρμόζονται και για ποιο λόγο, χωρίς να απαιτείται χειροκίνητη συγγραφή [160].

5.2.2.3 Εμπειρία Χρήστη

Σημειώνεται ότι η αξιολόγηση της παρούσας ενότητας βασίστηκε στη μελέτη των εγχειριδίων χρήσης, καθώς τεχνικοί περιορισμοί δεν επέτρεψαν την εκτέλεση του λογισμικού σε περιβάλλον προσομοίωσης (VMware Pro). Σύμφωνα με την τεκμηρίωση, η εμπειρία χρήστη στο MONARC χαρακτηρίζεται από την προσπάθεια απλοποίησης της πολύπλοκης διαδικασίας διαχείρισης κινδύνου, προσφέροντας ένα σύγχρονο και φιλικό διαδικτυακό περιβάλλον που είναι προσβάσιμο μέσω

οποιοδήποτε browser. Ο διαδραστικός «πίνακας ελέγχου» (Dashboard) παρέχει άμεση εικόνα της ασφάλειας με γραφήματα, βοηθώντας στον γρήγορο εντοπισμό απειλών [161]. Η καταγραφή των περιουσιακών στοιχείων γίνεται μέσω μιας δενδρικής δομής που υποστηρίζει την αυτόματη μεταφορά (κληρονομικότητα) επιπτώσεων, εξοικονομώντας σημαντικό χρόνο [162]. Τέλος, οι έτοιμες βιβλιοθήκες και η ευκολία χρήσης καθιστούν το εργαλείο προσιτό ακόμα και σε μη εξειδικευμένους χρήστες, χωρίς να απαιτούνται περίπλοκες ρυθμίσεις [163].

5.2.3 Verinice

5.2.3.1 Τεχνική Ταυτότητα και Αδειοδότηση

Το Verinice αποτελεί μια από τις πιο αναγνωρισμένες ευρωπαϊκές λύσεις GRC, με ισχυρή βάση στη Γερμανία και έμφαση στα πρότυπα ISO 27001 και BSI IT-Grundschutz. Το BSI IT-Grundschutz αποτελεί το πρότυπο αναφοράς της Γερμανικής Κυβέρνησης για την ασφάλεια πληροφοριών. Σε αντίθεση με την πιο γενική προσέγγιση του ISO 27001, το IT-Grundschutz παρέχει μια λεπτομερή και αυστηρή μεθοδολογία με συγκεκριμένους τεχνικούς καταλόγους μέτρων (Compendium) για κάθε στοιχείο της υποδομής (π.χ. λειτουργικά συστήματα, δίκτυα, κτηριακές υποδομές). Το Verinice ενσωματώνει εγγενώς αυτούς τους καταλόγους, καθιστώντας το ιδανικό για οργανισμούς που απαιτούν συμμόρφωση με τα αυστηρά ευρωπαϊκά πρότυπα [138].

- **Μοντέλο Αδειοδότησης:** Επισήμως, ο πηγαίος κώδικας διατίθεται ελεύθερα, επιτρέποντας την ελεύθερη επισκόπηση. Ωστόσο, η εταιρεία χρεώνει για την παροχή του έτοιμου, εκτελέσιμου προγράμματος μέσω συνδρομής στο «Verinice Shop» [139]. Πρακτικά, αυτό σημαίνει ότι ενώ ο κώδικας είναι ανοικτός, η υπηρεσία της εύκολης εγκατάστασης και της άμεσης λειτουργίας αντιμετωπίζεται ως εμπορικό προϊόν [138].
- **Εύρος Δωρεάν Διάθεσης:** Για τους σκοπούς της αξιολόγησης και της εκπαίδευσης, διατίθεται η έκδοση verinice.EVAL. Πρόκειται για μια έκδοση η οποία, αν και παρέχει πλήρη λειτουργικότητα για τη δημιουργία ενός Συστήματος Διαχείρισης Ασφάλειας Πληροφοριών (ISMS), φέρει έναν κρίσιμο περιορισμό που την καθιστά ακατάλληλη για επαγγελματική χρήση. Δεν επιτρέπει την παραγωγή αναφορών και την εξαγωγή δεδομένων. Για την άρση

αυτού του περιορισμού και την πλήρη χρήση του λογισμικού, ο χρήστης καλείται να μεταβεί στην εμπορική έκδοση. Το κόστος για την απόκτηση του έτοιμου προς χρήση λογισμικού ανέρχεται στα 714,00€ (συμπεριλαμβανομένου ΦΠΑ) ανά έτος, ποσό που ουσιαστικά αφορά την υπηρεσία διάθεσης και υποστήριξης των ενημερώσεων. Παράλληλα, για λόγους οικονομίας, προωθείται η επιλογή της διετούς συνδρομής με συνολικό κόστος 1.285,20€, η οποία προσφέρει σαφές οικονομικό όφελος συγκριτικά με την ετήσια ανανέωση [139].

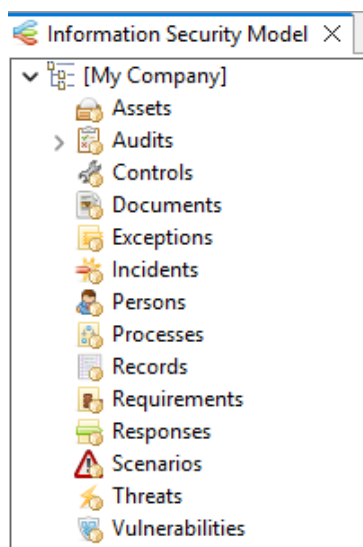
- **Αρχιτεκτονική και Απαιτήσεις:** Το εργαλείο βρίσκεται σε στάδιο τεχνολογικής μετάβασης, προσφέροντας δύο διακριτές αρχιτεκτονικές προσεγγίσεις [138]:

1. **Verinice.Client (Desktop):** Αποτελεί τη σταθερή και ευρέως διαδεδομένη έκδοση του λογισμικού (αυτή που εγκαταστάθηκε για τη δοκιμή). Είναι συμβατή με λειτουργικά συστήματα Windows, macOS και Linux, ενώ για τη λειτουργία της απαιτείται η ύπαρξη περιβάλλοντος Java (JRE) στον χρήστη. Ως εφαρμογή που εκτελείται τοπικά, χρησιμοποιεί τους πόρους του συστήματος του χρήστη. Οι ελάχιστες απαιτήσεις για την ομαλή λειτουργία της αυτόνομης έκδοσης είναι 4 GB μνήμης RAM (με ελάχιστο αποδεκτό το 1 GB) και 4 GB ελεύθερου χώρου στον σκληρό δίσκο για την αποθήκευση της τοπικής βάσης δεδομένων. Σε αντίθεση με τις web εφαρμογές, εδώ η επεξεργαστική ισχύς βαρύνει τον υπολογιστή του χρήστη, επομένως συνιστάται σύγχρονος επεξεργαστής για ταχύτερη εκτέλεση των αναλύσεων κινδύνου [140].
2. **Verinice.veo (Web-based):** Πρόκειται για τη νέα γενιά του εργαλείου, η οποία είναι αμιγώς διαδικτυακή (cloud-native) και επιτρέπει τη χρήση μέσω φυλλομετρητή [138]. Ωστόσο, η έκδοση αυτή προωθείται κυρίως ως εμπορική λύση ή με χρονικά περιορισμένη δοκιμή (30 ημερών) και δεν διατίθεται ελεύθερα για τοπική εγκατάσταση όπως η έκδοση Desktop Client [139].

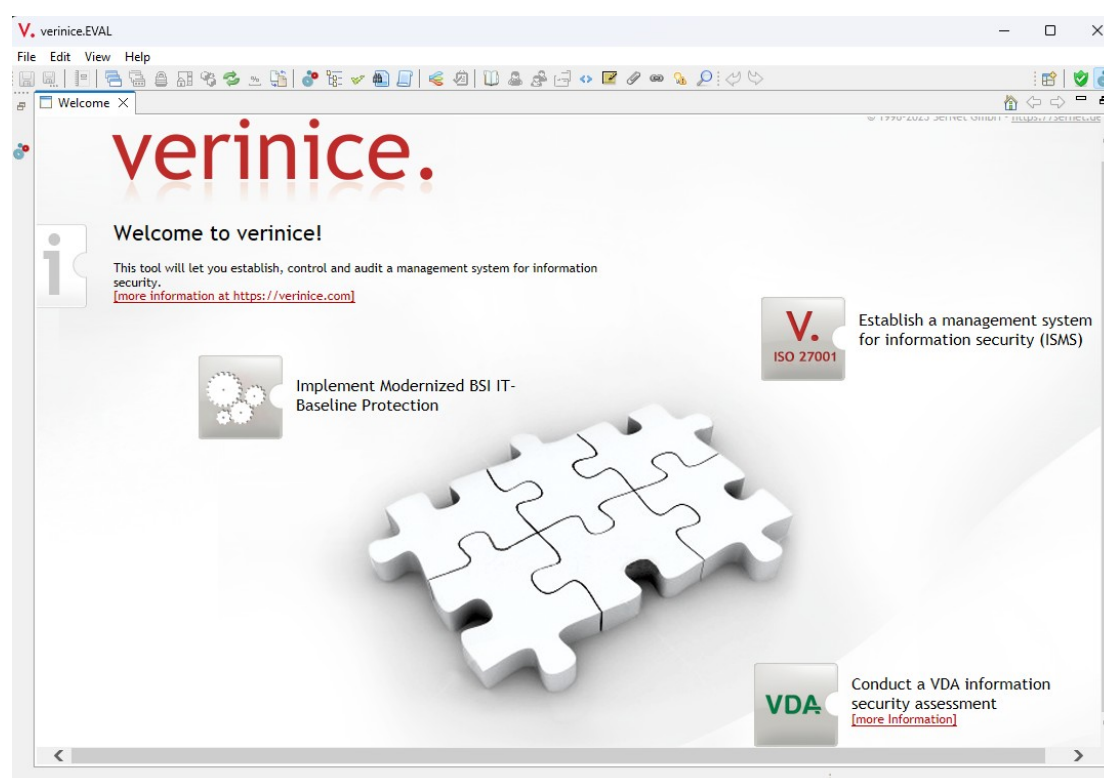
5.2.3.2 Λειτουργικότητα Διαχείρισης Κινδύνου

Η λειτουργική προσέγγιση του Verinice εστιάζει στην αυστηρή τυποποίηση και την ιεραρχική μοντελοποίηση, προσφέροντας εξειδικευμένα εργαλεία για κάθε στάδιο του κύκλου ζωής της διαχείρισης κινδύνου.

- **Διαχείριση Περιουσιακών Στοιχείων:** Σε αντίθεση με τις απλές λίστες καταγραφής, το Verinice υιοθετεί μια ιεραρχική δομή (Tree Structure) για την αποτύπωση των περιουσιακών στοιχείων [141]. Επιπλέον, υποστηρίζεται η μαζική εισαγωγή δεδομένων από εξωτερικές πηγές (CSV, XML), καθώς και η χρήση ειδικών «import agents» για την άντληση δεδομένων από υφιστάμενα εργαλεία απογραφής δικτύου (π.χ. Network Inventory) [138].

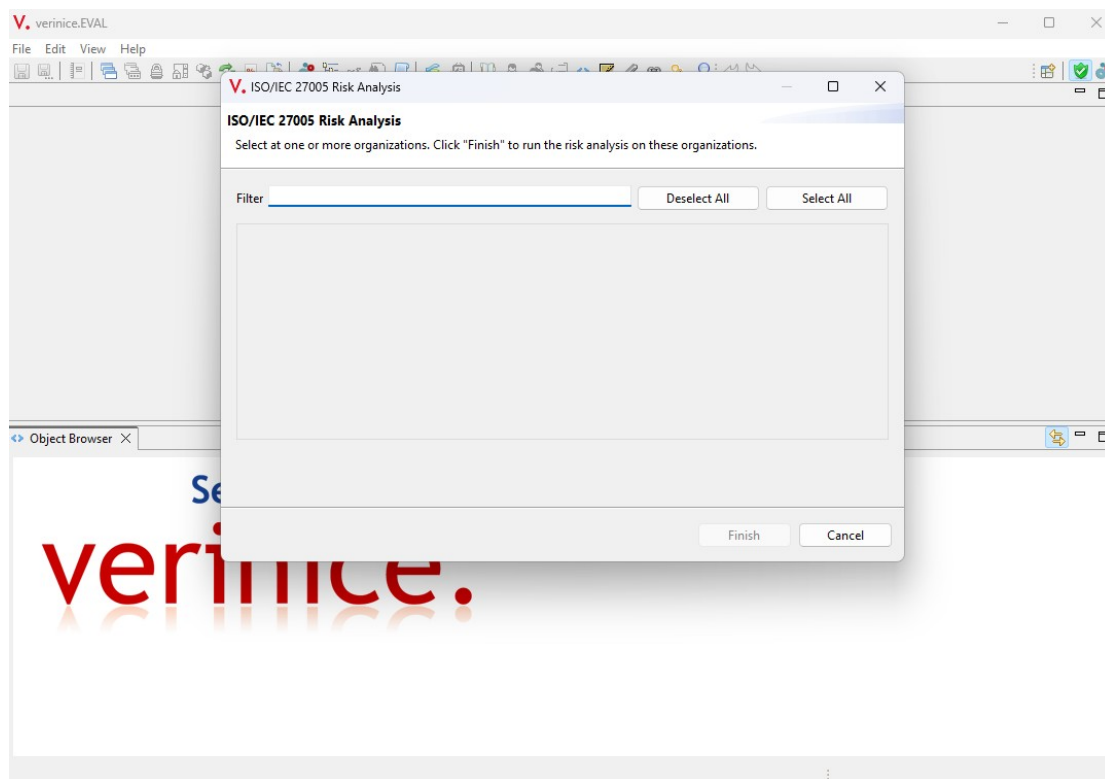


- **Προεγκατεστημένες Βιβλιοθήκες:** Αυτό αποτελεί το σημαντικότερο πλεονέκτημα του εργαλείου. Κατά την εκκίνηση, το Verinice δεν απαιτεί από τον χρήστη να εισάγει δεδομένα από το μηδέν, αλλά παρέχει έτοιμα «Προφίλ» (Perspectives) βασισμένα σε διεθνή πρότυπα. Συγκεκριμένα, ενσωματώνει πλήρως το πρότυπο ISO/IEC 27001 (για τη δημιουργία ISMS), τους αναλυτικούς καταλόγους του BSI IT-Grundschutz (με χιλιάδες έτοιμες απειλές και μέτρα), καθώς και το πρότυπο VDA/ISA για την αυτοκινητοβιομηχανία



[138]. Η ύπαρξη αυτών των βιβλιοθηκών επιτρέπει την άμεση αντιστοίχιση ευπαθειών και μέτρων ασφαλείας χωρίς χειροκίνητη πληκτρολόγηση [141].

- **Μηχανισμός Υπολογισμού:** Η διαδικασία ανάλυσης κινδύνου είναι τυποποιημένη και βασίζεται ρητά στο πρότυπο ISO/IEC 27005. Μέσω της ειδικής λειτουργίας «Run ISO/IEC 27005 Risk Analysis», το εργαλείο αυτοματοποιεί τον συσχετισμό μεταξύ των περιουσιακών στοιχείων, των απειλών και των ευπαθειών που έχουν επιλεγεί από τις βιβλιοθήκες. Ο χρήστης έχει τη δυνατότητα να ορίσει το επίπεδο επιπτώσεων και πιθανοτήτων, ενώ το σύστημα παράγει αυτόματα τα αποτελέσματα κινδύνου για τους επιλεγμένους οργανισμούς ή τμήματα της υποδομής [141].



- **Αναφορές:** Στον τομέα αυτό εντοπίζεται ο σημαντικότερος διαχωρισμός μεταξύ των εκδόσεων. Ενώ η πλατφόρμα έχει τη δυνατότητα παραγωγής πλούσιων αναφορών (όπως σχέδιο αντιμετώπισης κινδύνου, συγκεντρωτικά dashboards), αυτή η λειτουργία είναι κλειδωμένη στη δωρεάν έκδοση (EVAL) [139]. Στην πλήρη εμπορική έκδοση, οι αναφορές παράγονται σε επεξεργάσιμες μορφές (Word, Excel, PDF), επιτρέποντας την άμεση παρουσίασή τους στη διοίκηση ή σε εξωτερικούς ελεγκτές.

5.2.3.3 Εμπειρία Χρήστη

Η εμπειρία χρήσης του Verinice χαρακτηρίζεται από μια έντονη αντίθεση ανάμεσα στο περιεχόμενο και την πολυπλοκότητα της διεπαφής, η οποία κρίνεται ως το ασθενέστερο σημείο του λογισμικού. Το γραφικό περιβάλλον, βασισμένο σε παλαιότερη τεχνολογία (Eclipse RCP), είναι οπτικά «φορτωμένο», με πληθώρα παραθύρων και καρτελών που δημιουργούν σύγχυση στον χρήστη. Η εκμάθηση του εργαλείου είναι δύσκολη και απαιτητική, καθώς ο τρόπος που λειτουργεί δεν είναι ξεκάθαρος. Όπως φάνηκε στη δοκιμή, ακόμα και με τη βοήθεια του βίντεο επίδειξης λειτουργίας, η διαδικασία παραμένει μπερδεμένη για έναν αρχάριο χρήστη. Ωστόσο, σημαντικό αντίβαρο στη δύσχρηστη φύση του αποτελεί η ποιότητα των ενσωματωμένων βιβλιοθηκών. Η ύπαρξη έτοιμων καταλόγων και προτύπων (όπως ISO 27001, BSI IT-Grundschutz, VDA/ISA) λειτουργεί λυτρωτικά, προσφέροντας έτοιμη τη δομή συμμόρφωσης για εξειδικευμένους κλάδους. Συμπερασματικά, το Verinice αποτελεί μια ισχυρή αλλά δυσπρόσιτη λύση που, αν και προσφέρει έτοιμο περιεχόμενο, απαιτεί σημαντική επένδυση χρόνου και κόπου για την εκμάθησή του [141].

5.2.4 EAR/PILAR

Η σουίτα εργαλείων EAR/PILAR αποτελεί την τυποποιημένη λύση λογισμικού που χρησιμοποιείται ευρέως στην Ισπανική Δημόσια Διοίκηση για τη διαχείριση κινδύνου. Αναπτύσσεται με τη στρατηγική υποστήριξη του Ισπανικού Εθνικού Κέντρου Κρυπτολογίας (CCN). Το εργαλείο βασίζεται αυστηρά στη μεθοδολογία MAGERIT (επίσημη μεθοδολογία ανάλυσης και διαχείρισης κινδύνου της Ισπανικής Κυβέρνησης), ενώ παράλληλα υποστηρίζει διεθνή πρότυπα όπως το ISO/IEC 27002:2022 και το ENS 2022. Το λογισμικό δεν είναι ένα, αλλά διατίθεται σε τέσσερις διακριτές εκδόσεις ανάλογα με την πολυπλοκότητα του οργανισμού [142, 143]:

- **μPILAR:** Προορίζεται για μικρά συστήματα που ακολουθούν μια ομοιογενή προσέγγιση ασφάλειας, προσφέροντας γρήγορη ανάλυση.
- **PILAR Basic:** Απευθύνεται σε χρήστες που χρειάζονται μια τυπική ανάλυση κινδύνου. Παρέχει δυνατότητες οργάνωσης σε τομείς ασφαλείας και υποστηρίζει τη χρήση μέτρων ασφαλείας.
- **PILAR RM (Risk Management):** Είναι η πλήρης έκδοση για διαχείριση κινδύνου. Επιτρέπει τη λεπτομερή παραμετροποίηση (π.χ. διαχείριση απειλών, δημιουργία προφίλ) και υποστηρίζει πολλαπλά επίπεδα χρηστών και σύνθετες αναφορές.

- **PILAR BCM (Business Continuity Management):** Εξειδικευμένη έκδοση για τη Διαχείριση Επιχειρησιακής Συνέχειας. Εστιάζει στον υπολογισμό των στόχων ανάκαμψης (RTO-Recovery Time Objective) και των σημείων επαναφοράς δεδομένων (RPO-Recovery Point Objective) [143].

5.2.4.1 Τεχνική Ταυτότητα και Αδειοδότηση

Η οικογένεια εφαρμογών EAR/PILAR ακολουθεί μια ενιαία τεχνική και εμπορική προσέγγιση σε όλες τις εκδόσεις της (μPILAR, Basic, RM, BCM). Παρόλο που κάθε έκδοση απευθύνεται σε διαφορετικό μέγεθος οργανισμού, μοιράζονται τον ίδιο πυρήνα λογισμικού και το ίδιο πλαίσιο αδειοδότησης.

- **Μοντέλο Αδειοδότησης [142]:** Το λογισμικό είναι ιδιόκτητο και εμπορικό. Η αδειοδότηση είναι ευέλικτη και προσφέρει δύο διακριτούς τρόπους απόκτησης, οι οποίοι ισχύουν για όλες τις εκδόσεις της εφαρμογής:

- ο **Ως υπηρεσία (ετήσια συνδρομή):** Αφορά ετήσια ενοικίαση της άδειας χρήσης. Το πλεονέκτημα είναι το χαμηλότερο αρχικό κόστος και η συμπερίληψη όλων των αναβαθμίσεων που θα κυκλοφορήσουν εντός του έτους.

tool	size S	size M	size L
number of users	1	5	10
μPILAR	100 €	200 €	400 €
PILAR Basic	200 €	400 €	800 €
PILAR BCM	350 €	700 €	1,400 €
PILAR RM	500 €	1,000 €	2,000 €
PILAR RM + BCM	700 €	1,400 €	2,800 €
PILAR + BBDD	+30%	+30%	+30%
RMAT	750 €	1,500 €	3,000 €

*Αφορά την ετήσια ενοικίαση της άδειας χρήσης με όλες τις νέες εκδόσεις.

- ο **Ως προϊόν (εφάπαξ αγορά):** Αφορά την αγορά μόνιμης άδειας χρήσης για τη συγκεκριμένη έκδοση. Ο χρήστης πληρώνει μία φορά και του ανήκει το λογισμικό για πάντα. Ωστόσο για μελλοντικές αναβαθμίσεις απαιτείται ξεχωριστό συμβόλαιο συντήρησης.

tool	size S	size M	size L
number of users	1	5	10
μPILAR	250 €	500 €	1,000 €
PILAR Basic	500 €	1,000 €	2,000 €
PILAR BCM	1,000 €	2,000 €	4,000 €
PILAR RM	1,500 €	3,000 €	6,000 €
PILAR RM + BCM	2,000 €	4,000 €	8,000 €
PILAR + BBDD	+30%	+30%	+30%
RMAT	2,250 €	4,500 €	9,000 €

**Οι κάτοχοι προηγούμενης έκδοσης που επιθυμούν να μεταβούν στην τρέχουσα, δικαιούνται έκπτωση 80% επί της αρχικής τιμής του προϊόντος. Προαιρετικά, με ετήσιο κόστος ίσο με το 20% της αξίας αγοράς, παρέχεται αυτόματη πρόσβαση σε όλες τις νέες εκδόσεις για όσο διαρκεί το συμβόλαιο.*

Σημαντικές επισημάνσεις:

- **PILAR + BBDD:** Πρόσθετη λειτουργία για την έκδοση RM που επιτρέπει την αποθήκευση δεδομένων σε βάση δεδομένων για συνεργατική εργασία μεγάλων ομάδων.
 - **RMAT:** Ξεχωριστό εργαλείο παραμετροποίησης που επιτρέπει σε εξειδικευμένους χρήστες να δημιουργούν προσαρμοσμένες βιβλιοθήκες απειλών και μέτρων ασφαλείας.
- **Εύρος Δωρεάν Διάθεσης [142]:** Η πολιτική δωρεάν διάθεσης είναι κοινή για όλη την οικογένεια PILAR και χωρίζεται σε δύο επίπεδα χρήσης:
 - ο **Λειτουργία viewer (Δωρεάν):** Οποιοσδήποτε μπορεί να χρησιμοποιήσει το λογισμικό δωρεάν για να ανοίξει και να διαβάσει αρχεία ανάλυσης, χωρίς όμως δικαίωμα τροποποίησης.
 - ο **Λειτουργία αξιολόγησης:** Παρέχεται δυνατότητα πλήρους δοκιμής για 30 ημέρες. Ωστόσο, σε όλα τα εγχειρίδια (μPILAR, Basic, RM) τονίζεται ρητά ότι η έκδοση αυτή έχει συγκεκριμένους λειτουργικούς περιορισμούς:
 1. Δεν επιτρέπει την παραγωγή αναφορών
 2. Υπολογίζει μόνο έναν περιορισμένο αριθμό κινδύνων
 - **Αρχιτεκτονική και Απαιτήσεις [142]:** Η τεχνική βάση είναι κοινή για όλες τις παραλλαγές, καθώς όλες βασίζονται στη γλώσσα προγραμματισμού Java. Αυτό

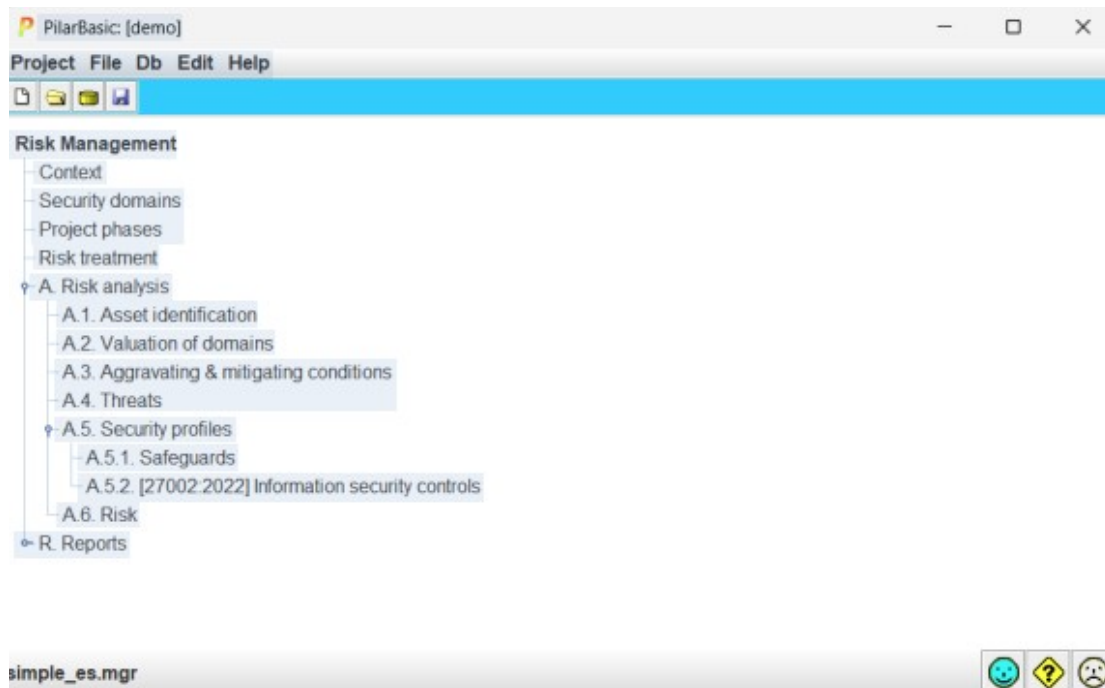
προσδίδει στην εφαρμογή συγκεκριμένα χαρακτηριστικά που αναγράφονται στους οδηγούς εγκατάστασης («First Time») κάθε έκδοσης:

- ο **Απαιτήσεις Λογισμικού:** Η μόνη αυστηρή απαίτηση που αναφέρεται είναι η ύπαρξη του Java Runtime Environment (JRE), έκδοση 8 ή νεότερη. Δεν απαιτείται συγκεκριμένο λειτουργικό σύστημα, καθώς η εφαρμογή είναι συμβατή με Windows, Linux και macOS.
- ο **Εφαρμογή:** Η αρχιτεκτονική της εφαρμογής είναι σχεδιασμένη ώστε να λειτουργεί χωρίς κλασική εγκατάσταση. Ο χρήστης απλώς αποσυμπίεζει τον φάκελο και εκτελεί το αρχείο (εκτελέσιμο .exe ή .jar), γεγονός που επιτρέπει τη λειτουργία της ακόμα και από USB φλασάκι, χωρίς να απαιτούνται δικαιώματα διαχειριστή στο μηχάνημα.
- ο **Διαχείριση Δεδομένων:**
 - Οι εκδόσεις μPILAR και Basic λειτουργούν με τοπικά αρχεία (.mgr), αποθηκεύοντας τα δεδομένα σε επίπεδο συστήματος αρχείων.
 - Η έκδοση RM είναι η μόνη που διαφοροποιείται αρχιτεκτονικά σε αυτό το σημείο, καθώς προσφέρει επιπλέον τη δυνατότητα σύνδεσης με βάση δεδομένων για τη διαχείριση μεγάλου όγκου δεδομένων.

5.2.4.2 Λειτουργικότητα Διαχείρισης Κινδύνου

- **Διαχείριση Περιουσιακών Στοιχείων:** Η βάση της μεθοδολογίας MAGERIT είναι ο εντοπισμός και η ιεράρχηση των στοιχείων που έχουν αξία για τον οργανισμό [144]. Το PILAR Basic υλοποιεί αυτή τη διαδικασία μέσω δύο βημάτων που εμφανίζονται στην κύρια οθόνη:
 - ο **Ταυτοποίηση:** Ο χρήστης καλείται να δημιουργήσει το δέντρο των περιουσιακών στοιχείων, διαχωρίζοντάς τα σε βασικά (πληροφορίες και υπηρεσίες) [145].
 - ο **Υποστηρικτικά** (όπως υλικό, λογισμικό, επικοινωνίες): Το σύστημα αναγνωρίζει αυτόματα τις εξαρτήσεις, μεταφέροντας τις απαιτήσεις ασφαλείας από τα βασικά στα υποστηρικτικά στοιχεία [146].

Ο χρήστης βαθμολογεί τη σημασία κάθε περιουσιακού στοιχείου (κλίμακα 0-10), καθορίζοντας έτσι το επίπεδο προστασίας που απαιτείται [147].



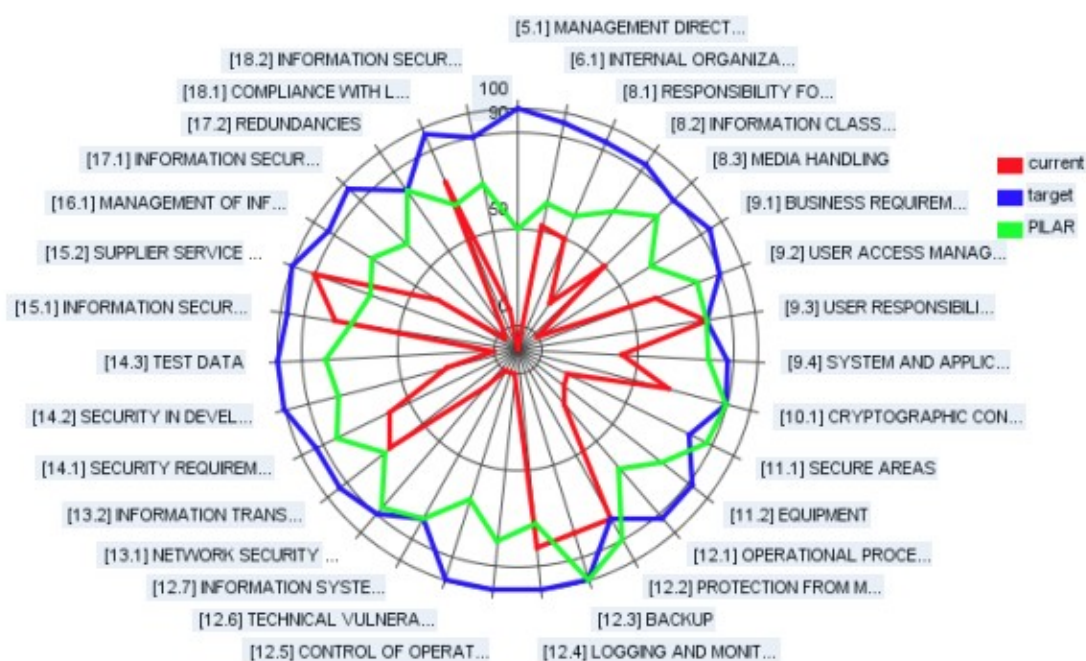
- **Προεγκατεστημένες Βιβλιοθήκες:** Ένα από τα σημαντικότερα πλεονεκτήματα του PIlAR Basic είναι ότι απαλλάσσει τον χρήστη από την ανάγκη να δημιουργεί λίστες απειλών ή μέτρων από το μηδέν. Η εφαρμογή έρχεται με ενσωματωμένες βιβλιοθήκες που ενεργοποιούνται μέσω της επιλογής προφίλ ασφαλείας:
 - ο **Πρότυπα ασφαλείας:** Το εργαλείο παρέχει έτοιμα σύνολα μέτρων ασφαλείας βασισμένα σε διεθνή πρότυπα (όπως ISO 27002) ή επίπεδα ασφαλείας (π.χ. Low, Medium, High). Ο χρήστης επιλέγει το επιθυμητό προφίλ και η εφαρμογή «γεμίζει» αυτόματα τις απαιτήσεις για κάθε περιουσιακό στοιχείο [148].

- ο **Κατάλογοι Απειλών:** Βάσει του τύπου του περιουσιακού στοιχείου, το σύστημα προτείνει αυτόματα τις σχετικές απειλές από την πρότυπη βιβλιοθήκη του MAGERIT, καθώς και την τυπική πιθανότητα εμφάνισής τους [149].

rec...	level	control	do...	ba...	co...	current	target	PILAR
		[27002 2022] Information security controls				L2	L4	L2-L3 (...)
3		✓ [5] Organizational controls /PR CR DC		...		L2	L4	L2-L3
3		✓ [5.1] Policies for information security /PR				L2	L4	L3 (L2)
3		✓ [5.2] Information security roles and responsibilities /PR				L2	L4	L3 (L2)
2		✓ [5.3] Segregation of duties /PR				L2	L4	L2 (L2-...)
3		✓ [5.4] Management responsibilities /PR				L2	L4	L3 (L2)
3		✓ [5.5] Contact with authorities /PR CR				L2	L4	L3 (L2)
3		✓ [5.6] Contact with special interest groups /PR CR				L2	L4	L3 (L2-...)
3		✓ [5.7] Threat intelligence /PR CR DC				L2	L4	L3
		✓ [5.8] Information security in project management /PR		n.a.				
3		✓ [5.9] Inventory of information and other associated assets /PR				L2	L4	L3 (L2-...)
3		✓ [5.10] Acceptable use of information and other associated assets /PR				L2	L4	L3 (L2)
2		✓ [5.11] Return of assets /PR				L2	L4	L2 (L3)
1		✓ [5.12] Classification of information /PR				L2	L4	L2
1		✓ [5.13] Labelling of information /PR				L2	L4	L2 (L2-...)
1		✓ [5.14] Information transfer /PR				L2	L4	L2 (L2-...)
3		✓ [5.15] Access control /PR				L2	L4	L3 (L2)

- **Μηχανισμός Υπολογισμού:** Ο υπολογισμός του κινδύνου στο PILAR Basic είναι δυναμικός και πραγματοποιείται σε πραγματικό χρόνο καθώς ο χρήστης εισάγει δεδομένα [150]. Ο μηχανισμός λειτουργεί συγκρίνοντας δύο καταστάσεις, οι οποίες εμφανίζονται ως διακριτές φάσεις στην εφαρμογή:
 - ο **Τρέχουσα κατάσταση:** Υπολογίζει τον κίνδυνο με βάση τα μέτρα που έχουν ήδη υλοποιηθεί στον οργανισμό.
 - ο **Στόχος:** Υπολογίζει τον προβλεπόμενο κίνδυνο εφόσον υλοποιηθούν τα προτεινόμενα μέτρα [151].

Το αποτέλεσμα οπτικοποιείται και δείχνει άμεσα αν ο κίνδυνος υπερβαίνει το αποδεκτό όριο, λαμβάνοντας υπόψη την πιθανότητα της απειλής και την επίπτωση στο περιουσιακό στοιχείο [152].



- **Αναφορές:** Η τελική φάση της λειτουργικότητας, όπως περιγράφεται στο μενού της εφαρμογής, είναι η παραγωγή τεκμηρίωσης. Το PILAR Basic διαθέτει ενσωματωμένη μηχανή παραγωγής αναφορών που εξάγει τα αποτελέσματα σε επεξεργάσιμη μορφή [153]. Οι διαθέσιμες αναφορές περιλαμβάνουν:

1. Σύνοψη για τη διοίκηση (Executive Summary).
2. Αναλυτική τεχνική έκθεση (Technical Report).
3. Δήλωση εφαρμογής (Statement of Applicability).
4. Σχέδιο αντιμετώπισης κινδύνων (Risk Treatment Plan).

5.2.4.3 Εμπειρία Χρήστη

Η εμπειρία χρήστη στο PILAR Basic απέχει από τα σύγχρονα πρότυπα σχεδιασμού (Modern UI). Το περιβάλλον εργασίας δεν διαθέτει μοντέρνα αισθητική, αλλά παραπέμπει σε παλαιότερα, κλασικά λογισμικά, με μια αυστηρή και «βιομηχανική» εμφάνιση. Το μενού είναι απλό στη δομή του, χωρίς γραφιστικές υπερβολές, αλλά δεν είναι διαισθητικό για έναν νέο χρήστη. Οι πολύπλοκες επιλογές

δεν είναι άμεσα κατανοητές χωρίς προηγούμενη εξοικείωση. Παρόλο που το interface δεν είναι ελκυστικό, η ροή εργασίας είναι συγκεκριμένη. Το εργαλείο γίνεται πλήρως κατανοητό και λειτουργικό, εφόσον ο χρήστης αφιερώσει τον απαραίτητο χρόνο για έρευνα και εκπαίδευση πάνω στον τρόπο λειτουργίας του. Τέλος, καθοριστικό ρόλο στην εμπειρία παίζει η κατάτμηση του λογισμικού σε διαφορετικές εκδόσεις (μPILAR, Basic, RM, BCM). Από τη μία πλευρά, αυτό μπορεί να προκαλέσει αρχική σύγχυση, καθώς απαιτείται έρευνα από τον εκάστοτε ενδιαφερόμενο για να αντιληφθεί τις διαφορές και να επιλέξει το σωστό εργαλείο. Από την άλλη, μόλις γίνει κατανοητή η λογική της οικογένειας PILAR, αυτή η ποικιλία λειτουργεί υπέρ του χρήστη. Προσφέρει ευελιξία τόσο στο κόστος όσο και στη λειτουργικότητα, επιτρέποντας στον κάθε οργανισμό να προμηθευτεί ακριβώς την έκδοση που καλύπτει τις ανάγκες του, χωρίς να πληρώνει για αχρείαστα χαρακτηριστικά.

5.3 Συγκριτική Αξιολόγηση και Συμπεράσματα

Στον πίνακα που ακολουθεί παρουσιάζεται η συγκριτική επισκόπηση των τεσσάρων εργαλείων λογισμικού (SimpleRisk, MONARC, Verinice, EAR/PILAR), βάσει των τεχνικών και λειτουργικών κριτηρίων που ορίστηκαν στη μεθοδολογία της παρούσας μελέτης.

Κριτήρια Σύγκρισης	SimpleRisk	MONARC	Verinice	EAR/PILAR (Basic)
Τεχνική Ταυτότητα και Αδειοδότηση				
Μοντέλο Αδειοδότησης	Ο βασικός πυρήνας είναι ανοικτός και δωρεάν. Τι Πληρώνεις: Τα πρόσθετα Modules (λειτουργίες) που κουμπώνουν πάνω στον πυρήνα.	Όλος ο κώδικας και η εφαρμογή είναι δωρεάν. Τι Πληρώνεις: Τίποτα. Δεν υπάρχει εμπορικό σκέλος λογισμικού.	Ο κώδικας είναι ανοικτός, αλλά το έτοιμο πρόγραμμα (exe) χρεώνεται. Τι Πληρώνεις: Την έτοιμη εφαρμογή και τα updates.	Ο κώδικας είναι κλειστός και ιδιόκτητος. Τι Πληρώνεις: Την άδεια χρήσης εξ αρχής για να λειτουργήσει το πρόγραμμα.

Εύρος Δωρεάν Διάθεσης	Δωρεάν (Core) Το κόστος αφορά μόνο τα Extras (Τιμή κατόπιν επικοινωνίας). Περιορισμός του δωρεάν εργαλείου: Απαιτεί εταιρικό email για τη λήψη.	Δωρεάν Δεν υπάρχει κανένα κόστος κτήσης ή συνδρομής. Πλήρης πρόσβαση σε όλες τις λειτουργίες χωρίς κανέναν περιορισμό.	~714 €/έτος Η συνδρομή κοστίζει 714,00€ (έτος) ή 1.285,20€ (διετία). Περιορισμός του δωρεάν εργαλείου: Δεν επιτρέπει την αποθήκευση αναφορών και την εξαγωγή.	Ποικίλλει (100€ - 8.000€)/έτος Τιμές ανάλογα την έκδοση και τον τύπο (Ενοίκιο/Αγορά). Περιορισμός του δωρεάν εργαλείου (Trial): Δοκιμή 30 ημερών χωρίς δυνατότητα εκτύπωσης/εξαγωγής.
	Web-based Εγκατάσταση σε Linux Server. Απαιτήσεις: Χαμηλές (2 vCPU, 2GB RAM). Πρόσβαση μέσω Browser.	Web-based Εγκατάσταση σε Docker/VM. Απαιτήσεις: Μέτριες (4GB RAM για VM). Πρόσβαση μέσω Browser.	Desktop Εξαρτημένη εφαρμογή (Eclipse RCP). Απαιτήσεις: Εκτελείται τοπικά σε όλα τα OS. Μέτριες (4GB RAM).	Desktop Αυτόνομη εφαρμογή. Απαιτήσεις: Πολύ χαμηλές. Απαιτεί μόνο Java Runtime (JRE 8+).
Λειτουργικότητα Διαχείρισης Κινδύνου				
Διαχείριση Περιουσιακών Στοιχείων	Λίστες και IP Scanning Επίπεδη καταγραφή σε λίστες. Δηλαδή δεν έχει δενδρική δομή με φακέλους και υποφακέλους. Κλειδί: Αυτοματισμός μέσω σάρωσης για γρήγορη εύρεση συσκευών (ταχύτητα).	Δέντρο Κληρονομικότητας Δυναμική δενδρική δομή. Γίνεται διαχωρισμός των περιουσιακών στοιχείων που κινδυνεύουν και δεν κινδυνεύουν και εστιάζουμε στην πρώτη περίπτωση. Κλειδί: Η αξία και οι επιπτώσεις «κληρονομούνται» αυτόματα από τις υπηρεσίες στον εξοπλισμό.	Δέντρο Απογραφής Ιεραρχική αποτύπωση υποδομών. Κλειδί: Εστίαση στη μαζική εισαγωγή από εργαλεία απογραφής IT.	Δομή Εξαρτήσεων (MAGERIT) Αυστηρός διαχωρισμός Essential/Support. Κλειδί: Αυτόματη συσχέτιση εξαρτήσεων μεταξύ επιπέδων. Υπολογισμός των επιπτώσεων.
	Περιλαμβάνει mappings για συμμόρφωση με: NIST, ISO, PCI DSS, HIPAA	Βιβλιοθήκη αντικειμένων και απειλών βάσει: ISO 27005 και CASES	Πλήρης ενσωμάτωση καταλόγων: BSI IT-Grundschutz, ISO 27001, VDA	Έτοιμα πακέτα μέτρων και απειλών βάσει: MAGERIT και ISO 27002

Μηχανισμός Υπολογισμού	Παραμετροποιήσιμος Υπολογίζει εγγενή (χωρίς μέτρα) και υπολειπόμενο κίνδυνο (μετά τα μέτρα). Λειτουργία: Επιτρέπει τη δημιουργία προσαρμοσμένων μαθηματικών τύπων για τον υπολογισμό του σκορ.	Ημι-ποσοτικός Χρησιμοποιεί πίνακες Επιπτώσεων x Πιθανότητας. Λειτουργία: Η επίπτωση «κληρονομείται» αυτόματα από την επιχειρησιακή διαδικασία στον τεχνικό εξοπλισμό, γλιτώνοντας χρόνο.	Τυποποιημένος (ISO 27005) Εκτελεί αυστηρή ανάλυση βάσει ISO 27005. Λειτουργία: Συσχετίζει αυτόματα: Απειλή→Ευπάθεια→Μέτρο→Κίνδυνος, όπως ορίζει το ISO.	Δυναμικός (Real-time) Υπολογίζει σε πραγματικό χρόνο την τρέχουσα και στοχευμένη κατάσταση. Λειτουργία: Ο κίνδυνος αναπροσαρμόζεται σε πραγματικό χρόνο ανάλογα με το ποσοστό αποτελεσματικότητας των μέτρων.
	Αναφορές Παρέχει εποπτικά Dashboards και γραφήματα τάσεων (Risk Trends) για άμεση οπτική ενημέρωση. Η δυνατότητα πλήρους εξαγωγής αναλυτικών αναφορών απαιτεί συνήθως την αγορά επιπλέον modules.	Παράγει αυτόματα τη δήλωση εφαρμογής (Statement of Applicability), πίνακες κινδύνου και σχέδιο αντιμετώπισης. Προσφέρει δωρεάν εξαγωγή όλων των στοιχείων σε αρχεία μορφής PDF και Excel.	Η δωρεάν έκδοση δεν επιτρέπει την παραγωγή ή εξαγωγή καμίας αναφοράς. Η πλήρης εμπορική έκδοση παρέχει όλες τις αναφορές σε επεξεργάσιμες μορφές (Word, Excel, PDF).	Η δοκιμαστική έκδοση (Trial) δεν επιτρέπει την εκτύπωση ή εξαγωγή αρχείων. Η πλήρης εμπορική έκδοση παρέχει εξειδικευμένες αναφορές (Executive και Technical Reports) για κάθε επίπεδο διοίκησης.
Εμπειρία Χρήστη	Σύγχρονο Περιβάλλον Διαθέτει μοντέρνα γραφικά και dashboards. Εκμάθηση: Η πλοήγηση είναι ευχάριστη, αν και τα μενού είναι πυκνά σε πληροφορία αρχικά.	Διασθητική Πλοήγηση Οργάνωση με λειτουργίες drag-and-drop και δενδρική δομή. Εκμάθηση: Ομαλή, καθώς το περιβάλλον καθοδηγεί τον χρήστη στη διαδικασία.	Σύνθετο Περιβάλλον Περιβάλλον πολλαπλών παραθύρων και καρτελών (παλαιάς τεχνολογίας). Εκμάθηση: Απότομη (Δύσκολο). Απαιτεί σημαντικό χρόνο εξοικείωσης.	Λιτό και Αυστηρό Απλή σχεδίαση χωρίς γραφιστικά στοιχεία με βιομηχανικό προφίλ. Εκμάθηση: Απαιτεί εκπαίδευση στη μεθοδολογία για να κατανοηθεί η ροή εργασίας.

Συμπεράσματα

Η συγκριτική επισκόπηση των τεσσάρων εργαλείων λογισμικού (SimpleRisk, MONARC, Verinice, EAR/PILAR) αποκαλύπτει μια σημαντική ανομοιογένεια στην αγορά των συστημάτων GRC. Αν και όλα τα εργαλεία εξυπηρετούν τον κοινό σκοπό της διαχείρισης κινδύνου, προσεγγίζουν το πρόβλημα από διαφορετικές αφετηρίες, δημιουργώντας σαφείς διαχωριστικές γραμμές ως προς τη φιλοσοφία χρήσης, το βάθος της ανάλυσης και το οικονομικό μοντέλο.

Σε επίπεδο αδειοδότησης και κόστους, το MONARC ξεχωρίζει ως η μοναδική λύση που προσφέρει το σύνολο των δυνατοτήτων της χωρίς κανένα κόστος, καθιστώντας το ιδανικό για οργανισμούς με περιορισμένο προϋπολογισμό. Αντιθέτως,

τα SimpleRisk και Verinice ακολουθούν υβριδικά μοντέλα, όπου η πλήρης λειτουργικότητα απαιτεί πληρωμή, ενώ το EAR/PILAR παραμένει μια αμιγώς εμπορική λύση με υψηλό κόστος κτήσης αλλά και εξειδικευμένες δυνατότητες.

Ως προς τη μεθοδολογική προσέγγιση, παρατηρείται μια κλιμάκωση από την απλότητα στην αυστηρότητα:

- Το SimpleRisk εστιάζει στην ταχύτητα και την εποπτεία, χρησιμοποιώντας επίπεδες λίστες και αυτοματισμούς σάρωσης, θυσιάζοντας όμως τη δομική λεπτομέρεια.
- Το MONARC εισάγει την καινοτομία της «κληρονομικότητας», προσφέροντας μια ισορροπημένη προσέγγιση που μειώνει τον φόρτο εργασίας μέσω της έξυπνης μεταφοράς επιπτώσεων από τις υπηρεσίες στον εξοπλισμό.
- Το Verinice λειτουργεί ως εργαλείο συμμόρφωσης, βασισμένο σε αυστηρά πρότυπα (ISO/BSI) και δέντρα απογραφής, ιδανικό για ελέγχους αλλά δύσκαμπτο στη χρήση.
- Το EAR/PILAR προσφέρει το μεγαλύτερο αναλυτικό βάθος με τη μεθοδολογία MAGERIT, υπολογίζοντας δυναμικά τον κίνδυνο και τις εξαρτήσεις, απευθυνόμενο όμως κυρίως σε εξειδικευμένους αναλυτές.

Τέλος, η εμπειρία χρήστη επιβεβαιώνει το χάσμα μεταξύ των σύγχρονων διαδικτυακών εφαρμογών και των παραδοσιακών εφαρμογών γραφείου. Οι web-based λύσεις (SimpleRisk, MONARC) προσφέρουν σύγχρονα, συνεργατικά περιβάλλοντα με εύκολη εκμάθηση. Στον αντίποδα, οι Desktop εφαρμογές (Verinice, PILAR) χαρακτηρίζονται από «βιομηχανική» αισθητική και υψηλή πολυπλοκότητα, απαιτώντας σημαντικό χρόνο εξοικείωσης. Συνοψίζοντας:

- Για οργανισμούς που αναζητούν μια ολοκληρωμένη, δωρεάν και συνεργατική λύση, το MONARC αποτελεί τη βέλτιστη επιλογή.
- Για όσους προτάσσουν την οπτικοποίηση και την ευκολία χρήσης, το SimpleRisk προσφέρει την καλύτερη εποπτεία.
- Για απαιτήσεις αυστηρής συμμόρφωσης με ευρωπαϊκά πρότυπα (BSI/ISO), το Verinice είναι μονόδρομος.
- Για περιβάλλοντα που απαιτούν μαθηματική ακρίβεια και δυναμική ανάλυση πολύπλοκων εξαρτήσεων, το EAR/PILAR αποτελεί το ισχυρότερο τεχνικά εργαλείο.

6. Βιβλιογραφία

ISO 27005

- [1]: "ISO (the International Organization for Standardization) and IEC (the International Electrotechnical Commission) form the specialized system for worldwide standardization.", σελ. 5
- [2]: "National bodies that are members of ISO or IEC participate in the development of International Standards through technical committees established by the respective organization to deal with particular fields of technical activity.", σελ. 5
- [3]: "This document was prepared by Joint Technical Committee ISO/IEC JTC 1, Information technology, Subcommittee SC 27, Information security, cybersecurity and privacy protection.", σελ. 5
- [4]: "This fourth edition cancels and replaces the third edition (ISO/IEC 27005:2018), which has been technically revised.", σελ. 5
- [5]: Δραστηριότητες | ΕΛΟΤ - Ελληνικός Οργανισμός Τυποποίησης.
<https://elot.gr/drastiriotites-elot/>.
- [6]: "Fourth edition 2022-10", σελ. 1
- [7]: "all guidance text has been aligned with ISO/IEC 27001:2022, and ISO 31000:2018;", σελ. 5
- [8]: "the terminology has been aligned with the terminology in ISO 31000:2018;", σελ. 5
- [9]: "the structure of the clauses has been adjusted to the layout of ISO/IEC 27001:2022;", σελ. 5
- [10]: "For an explanation of the voluntary nature of standards... see www.iso.org/iso/foreword.html.", σελ. 5
- [11]: "ISO (the International Organization for Standardization) and IEC (the International Electrotechnical Commission) form the specialized system for worldwide standardization."
- [12]: "This document provides guidance to assist organizations to: fulfil the requirements of ISO/IEC 27001 concerning actions to address information security risks; perform information security risk management activities...", σελ. 7

[13]: "ISO (the International Organization for Standardization) and IEC (the International Electrotechnical Commission) form the specialized system for worldwide standardization.", σελ. 5

[14]: "National bodies that are members of ISO or IEC participate in the development of International Standards through technical committees...", σελ. 5

[15]: "This document is applicable to all organizations, regardless of type, size or sector.", σελ. 7

[16]: ΕΛΟΤ EN ISO/IEC 27005 | ΕΛΟΤ <https://eshop.elot.gr/product/106819>

[17]: "Top management is accountable for managing risks and should lead and drive risk assessments, including: ensuring that the necessary resources are allocated to managing risk", σελ. 33

[18]: "When making plans for routine risk assessments, organizations should take account of any calendar that applies to their general business processes and associated budget cycles. ... Funds are then granted (diminished or denied) later.", σελ. 31

[19]: "Proactive methods... can be used to identify vulnerabilities depending on... available resources (e.g. allocated funds, available technology, persons with the expertise to conduct the test).", σελ. 57

[20]: "This monitoring and review activity should address (but not be limited to): ... total cost of ownership; necessary resources.", σελ. 39

[21]: "This document is applicable to all organizations, regardless of type, size or sector. ... An organization... can also be a subset of a legal entity (e.g. the IT department of a company).", σελ. 7, 9

[22]: "risk: effect of uncertainty on objectives... In the context of information security management systems, information security risks can be expressed as effect of uncertainty on information security objectives.", σελ. 2

[23]: "The risk assessment should help the organization make decisions about the management of the risks that affect the achievement of its objectives.", σελ. 10

[24]: "The assets can be divided into two categories: primary/business assets... supporting assets (components of the information system on which one or several business assets are based).", σελ. 47

[25]: "This document provides guidance on: implementation of the information security risk requirements specified in ISO/IEC 27001... essential references within the standards developed by ISO/IEC JTC 1/SC 27", σελ. 6

[26]: "This document provides guidance to assist organizations to: fulfil the requirements of ISO/IEC 27001 concerning actions to address information security risks", σελ. 7

[27]: "This document contains detailed guidance on risk management and supplements the guidance in ISO/IEC 27003.", σελ. 6

[28]: "This document provides guidance on... implementation of risk management guidance in ISO 31000 in the context of information security.", σελ. 6

[29]: "Normative references... ISO/IEC 27000, Information technology — Security techniques — Information security management systems — Overview and vocabulary", σελ. 7

[30]: "As Figure 1 illustrates, the information security risk management process can be iterative for risk assessment and/or risk treatment activities.", σελ. 8

[31]: "This process is based on the general risk management process defined in ISO 31000.", σελ. 7

[32]: "strategic cycle, where business assets, risk sources and threats, target objectives or consequences to information security events are evolving from changes in the overall context of the organization.", σελ. 9

[33]: "operational cycle, where the above-mentioned elements serves as input information or changed criteria that will affect a risk assessment or assessment where the scenarios should be reviewed and updated.", σελ. 9

[34]: "The information security risk management process should be continually monitored, reviewed and improved as necessary.", σελ. 39

[35]: "ISO/IEC 27001 does not mandate a particular approach... ensure that repeated information security risk assessments produce consistent, valid and comparable results.", σελ. 16

[36]: "Nevertheless, there are two main approaches for assessment: an event-based approach and an asset-based approach.", σελ. 16

[37]: "Event-based approach: identify strategic scenarios through a consideration of risk sources, and how they use or impact interested parties to reach those risk's desired objective.", σελ. 17

[38]: "An event-based approach can establish high level or strategic scenarios without spending a considerable amount of time in identification of assets on a detailed level... Events and consequences can often be determined by a discovery of the concerns of top management", σελ. 17

- [39]: "Asset-based approach: identify operational scenarios, which are detailed in terms of assets, threats and vulnerabilities.", σελ. 17
- [40]: "With an asset-based approach, the underlying concept is that risks can be identified and assessed through an inspection of assets, threats and vulnerabilities. An asset is anything that has value to the organization and therefore requires protection.", σελ. 17
- [41]: "The asset-based approach can identify asset-specific threats and vulnerabilities and allows the organization to determine specific risk treatment on a detailed level.", σελ. 18
- [42]: "Identifying the contributory risk sources using an event-based assessment typically requires drilling down from the general level of the scenario to the detail level", σελ. 24
- [43]: "but an asset-based assessment typically searches upwards from the asset to the scenario, in order to provide visibility regarding how consequences accumulate.", σελ. 24
- [44]: "ISO/IEC 27001 does not mandate a particular approach to be used to fulfil the requirements in ISO/IEC 27001:2022, 6.1.2.", σελ. 16
- [45]: "Techniques for risk analysis based on consequences and likelihood can be: a) qualitative... b) quantitative... c) semiquantitative", σελ. 19
- [46]: "The categories and values used in Table A.2 and Table A.4 are only examples. The most appropriate value to assign to each level of likelihood depends on the risk profile and risk appetite of the organization.", σελ. 42
- [47]: "No single organization is likely to encounter the range of risk represented by the entirety of these example scales. The context of the organization... should be used to define realistic upper and lower limits", σελ. 45
- [48]: "The level of risk can be determined in many possible ways. It is commonly determined as a combination of the assessed likelihood and the assessed consequences for all relevant risk scenarios.", σελ. 22
- [49]: "Alternative calculations can include an asset value as well as likelihood and consequence.", σελ. 22
- [50]: "In addition, the calculation is not necessarily linear, e.g. it can be likelihood squared combined with consequence.", σελ. 22
- [51]: "In any case the level of risk should be determined using the criteria established as described in 6.4.3.4.", σελ. 22

[52]: "Table A.10 gives examples of typical threats. The list can be used during the threat assessment process.", σελ. 53

[53]: "Threats considered as risk sources can be deliberate, accidental or environmental (natural)... The list indicates for each threat type where D (deliberate), A (accidental), E (environmental) is relevant.", σελ. 53

[54]: "Table A.11 gives examples for vulnerabilities in various security areas, including examples of threats that can exploit these vulnerabilities.", σελ. 55

[55]: "The lists can provide help during the assessment of threats and vulnerabilities... In some cases, other threats can exploit these vulnerabilities as well.", σελ. 54

[56]: "Context establishment means assembling the internal and external context for information security risk management", σελ. 8

[57]: "ISO/IEC 27001 specifies requirements for an organization to establish and maintain information security risk criteria that include: a) the risk acceptance criteria; b) criteria for performing information security risk assessments.", σελ. 11

[58]: "It means the chosen method should ensure the following properties of results: consistency... comparability... validity", σελ. 16

[59]: "This can involve... involvement of expertise in the relevant field, or other ways to collect the information required", σελ. 8-9

[60]: "Particularly where the qualitative approach is adopted, risk analysts should undergo training and periodic practice against an anchoring reference scale to maintain the calibration of their judgement.", σελ. 41

[61]: "Top management is accountable for managing risks... ensuring that the necessary resources are allocated to managing risk", σελ. 33

[62]: "Interviews with top management and those people in the organization who have a responsibility for a business process can assist in identifying not only the relevant events", σελ. 17

[63]: "To increase the reliability of estimating likelihood, organizations should consider using: a) team assessments rather than individual assessments", σελ. 21

[64]: "The risk communication and consultation activity should be performed continually.", σελ. 34

[65]: "When making plans for routine risk assessments, organizations should take account of... associated budget cycles... This monitoring and review activity should address... total cost of ownership", σελ. 31, 39

[66]: "ISO/IEC 27001 specifies requirements for organizations to retain documented information concerning the risk assessment process... and results", σελ. 35

[67]: "Documented information... should contain: a) a definition of the risk criteria... b) the identity of the risk owner(s)... Documented information about the information security risk treatment process should contain descriptions of... how risk treatment plans are produced", σελ. 35-36

NIST

[68]: "NIST Special Publication 800-39 is the flagship document... The purpose... is to provide guidance for an integrated, organization-wide program for managing information security risk", NIST SP 800-39, σελ. 3

[69]: "The purpose of Special Publication 800-30 is to provide guidance for conducting risk assessments... amplifying the guidance in Special Publication 800-39.", NIST SP 800-30, σελ. 2

[70]: "Special Publication 800-30 is being revised to provide guidance on risk assessment as a supporting document to Special Publication 800-39.", NIST SP 800-39, σελ. 4

[71]: "National Institute of Standards and Technology U.S. Department of Commerce", NIST SP 800-39, σελ. 1 & NIST SP 800-30 Rev.1, σελ. 1

[72]: "This publication has been developed by NIST to further its statutory responsibilities under the Federal Information Security Management Act (FISMA), Public Law (P.L.) 107-347.", NIST SP 800-39, σελ. 3 & NIST SP 800-30 Rev.1, σελ. 3

[73]: "NIST is responsible for developing information security standards and guidelines, including minimum requirements for federal information systems...", NIST SP 800-39, σελ. 3 & NIST SP 800-30 Rev.1, σελ. 3

[74]: "This publication was developed by the Joint Task Force Transformation Initiative Interagency Working Group with representatives from the Civil, Defense, and Intelligence Communities...", NIST SP 800-39, σελ. 5 & NIST SP 800-30 Rev.1, σελ. 5

[75]: "March 2011", NIST SP 800-39, σελ. 1

[76]: "Special Publication 800-39 supersedes the original Special Publication 800-30 as the source for guidance on risk management.", NIST SP 800-39, σελ. 4

[77]: "September 2012", NIST SP 800-30 Rev.1, σελ. 1

[78]: "Nothing in this publication should be taken to contradict the standards and guidelines made mandatory and binding on federal agencies by the Secretary of Commerce under statutory authority.", NIST SP 800-39, σελ. 3 & NIST SP 800-30 Rev.1, σελ. 3

[79]: "This publication may be used by nongovernmental organizations on a voluntary basis...", NIST SP 800-39, σελ. 3 & NIST SP 800-30 Rev.1, σελ. 3

[80]: "...and is not subject to copyright in the United States. Attribution would, however, be appreciated by NIST.", NIST SP 800-39, σελ. 3 & NIST SP 800-30 Rev.1, σελ. 3

[81]: "The guidelines in this publication are applicable to all federal information systems other than those systems designated as national security systems...", NIST SP 800-30 Rev.1, σελ. 2 & NIST SP 800-39, σελ. 3

[82]: "State, local, and tribal governments, as well as private sector organizations are encouraged to consider using these guidelines, as appropriate.", NIST SP 800-30 Rev.1, σελ. 2 & NIST SP 800-39, σελ. 3

[83]: "The concepts and principles... are intended to be similar to and consistent with the processes and approaches described in International Organization for Standardization (ISO)... reduces the burden on organizations that must conform to ISO/IEC and NIST standards.", NIST SP 800-30 Rev.1, σελ. 3 & NIST SP 800-39, σελ. 4

[84]: "This publication may be used by nongovernmental organizations on a voluntary basis and is not subject to copyright in the United States.", NIST SP 800-30 Rev.1, σελ. 3 & NIST SP 800-39, σελ. 3

[85]: "Attribution would, however, be appreciated by NIST.", NIST SP 800-30 Rev.1, σελ. 3 & NIST SP 800-39, σελ. 3

[86]: "All NIST publications are available at <http://csrc.nist.gov/publications>.", NIST SP 800-30 Rev.1, σελ. 3 & NIST SP 800-39, σελ. 3

[87]: "To integrate the risk management process throughout the organization, a three-tiered approach is employed that addresses risk at the: (i) organization level; (ii) mission/business process level; and (iii) information system level.", NIST SP 800-39, σελ. 9

[88]: "Tier 1 addresses risk from an organizational perspective... Tier 1 implements the first component of risk management (i.e., risk framing), providing the context for all risk management activities carried out by organizations.", NIST SP 800-39, σελ. 9

[89]: "Tier 2 addresses risk from a mission/business process perspective... Tier 2 risk management activities include... establishing an enterprise architecture... Tier 2 activities directly affect the activities carried out at Tier 3.", NIST SP 800-39, σελ. 10

[90]: "Tier 3 addresses risk from an information system perspective... Tier 3 risk management activities include: (i) categorizing organizational information systems; (ii) allocating security controls... and (iii) managing the selection, implementation, assessment, authorization, and ongoing monitoring...", NIST SP 800-39, σελ. 10

[91]: "The risk management process is carried out seamlessly across the three tiers with the overall objective of... effective inter-tier and intra-tier communication... and a feedback loop for continuous improvement", NIST SP 800-39, σελ. 9

[92]: "NIST Special Publication 800-39 is the flagship document in the series of information security standards and guidelines developed by NIST in response to FISMA.", NIST SP 800-39, σελ. 3

[93]: "Risk assessment is a key component of a holistic, organization-wide risk management process as defined in NIST Special Publication 800-39", NIST SP 800-30 Rev.1, σελ. 4

[94]: "Special Publication 800-37, Guide for Applying the Risk Management Framework to Federal Information Systems...", NIST SP 800-39, σελ. 4

[95]: "Special Publication 800-53, Recommended Security Controls for Federal Information Systems and Organizations", NIST SP 800-39, σελ. 4

[96]: "The concepts and principles... are intended to be similar to and consistent with the processes and approaches described in International Organization for Standardization (ISO)... reducing the burden on organizations", NIST SP 800-30 Rev.1, σελ. 3

[97]: "Risk management is a comprehensive process that requires organizations to: (i) frame risk... (ii) assess risk; (iii) respond to risk... and (iv) monitor risk on an ongoing basis", NIST SP 800-39, σελ. 6

[98]: "Risk management... ensuring that risk-based decision making is integrated... using effective organizational communications and a feedback loop for continuous improvement", NIST SP 800-39, σελ. 6

[99]: "Risk assessment activities can be integrated with the steps in the Risk Management Framework (RMF), as defined in NIST Special Publication 800-37.", NIST SP 800-30 Rev.1, σελ. 20

[100]: "risk assessments are conducted throughout the system development life cycle, from pre-system acquisition... through system acquisition... and on into sustainment", NIST SP 800-30 Rev.1, σελ. ix

[101]: "Risk, and its contributing factors, can be assessed in a variety of ways, including quantitatively, qualitatively, or semi-quantitatively.", NIST SP 800-30 Rev.1, σελ. 14

[102]: "Quantitative assessments typically employ a set of methods... based on the use of numbers... This type of assessment most effectively supports cost-benefit analyses... rigor... is significantly lessened when subjective determinations are buried", NIST SP 800-30 Rev.1, σελ. 14

[103]: "Qualitative assessments typically employ a set of methods... based on nonnumerical categories or levels... supports communicating risk results to decision makers... range of values... is comparatively small, making the relative prioritization... difficult", NIST SP 800-30 Rev.1, σελ. 14

[104]: "Semi-quantitative assessments typically employ a set of methods... that uses bins, scales, or representative numbers... This type of assessment can provide the benefits of quantitative and qualitative assessments... relative prioritization among results is better supported", NIST SP 800-30 Rev.1, σελ. 14

[105]: "A preferred approach (or situation-specific set of approaches) can be selected based on organizational culture and, in particular, attitudes toward the concepts of uncertainty and risk communication.", NIST SP 800-30 Rev.1, σελ. 14

[106]: "There are no specific requirements with regard to... formality, rigor... methodologies, tools... Organizations have maximum flexibility on how risk assessments are conducted", NIST SP 800-30 Rev.1, σελ. ix

[107]: "The templates are exemplary and can be tailored by organizations in accordance with specific organizational mission/business requirements.", NIST SP 800-30 Rev.1, σελ. 29

[108]: "The assessment scales in this appendix can be used as a starting point with appropriate tailoring to adjust for any organization-specific conditions.", NIST SP 800-30 Rev.1, σελ. I-1

[109]: "The use of the templates is not required in order to conduct risk assessments.", NIST SP 800-30 Rev.1, σελ. 29

[110]: "A single risk model... cannot meet the diverse needs... The expectation... is that each organization... will define a risk model appropriate to its view of risk", NIST SP 800-30 Rev.1, σελ. 16

[111]: "Risk is a measure... typically a function of: (i) the adverse impacts... and (ii) the likelihood of occurrence.", NIST SP 800-30 Rev.1, σελ. 6

[112]: "Qualitative assessments typically employ... nonnumerical categories or levels (e.g., very low, low, moderate, high, very high).", NIST SP 800-30 Rev.1, σελ. 14

[113]: "The bins (e.g., 0-15, 16-35, 36-70, 71-85, 86-100) or scales (e.g., 1-10) translate easily into qualitative terms... while also allowing relative comparisons", NIST SP 800-30 Rev.1, σελ. 14

[114]: "Table I-2: Assessment Scale - Level of Risk (Combination of Likelihood and Impact)... High (Likelihood) + Moderate (Impact) = High (Risk)", NIST SP 800-30 Rev.1, σελ. I-1

[115]: "This broad definition also allows risk to be represented as a single value or as a vector (i.e., multiple values), in which different types of impacts are assessed separately.", NIST SP 800-30 Rev.1, σελ. 12

[116]: "Uncertainty is inherent in the evaluation of risk... The degree of uncertainty... can be communicated in the form of the results", NIST SP 800-30 Rev.1, σελ. 13

[117]: "The taxonomy and assessment scales in this appendix can be used by organizations as a starting point with appropriate tailoring to adjust for any organization-specific conditions.", NIST SP 800-30 Rev.1, σελ. D-1

[118]: "In general, types of threat sources include: (i) hostile cyber or physical attacks; (ii) human errors... (iii) structural failures... and (iv) natural and man-made disasters", NIST SP 800-30 Rev.1, σελ. 8

[119]: "Appendix D... (ii) an exemplary taxonomy of threat sources... (iii) an exemplary set of tailorable assessment scales for assessing those risk factors", NIST SP 800-30 Rev.1, σελ. D-1

[120]: "Appendix E... (ii) representative examples of adversarial threat events expressed as tactics, techniques, and procedures (TTPs) and non-adversarial threat events", NIST SP 800-30 Rev.1, σελ. E-1

[121]: "Predisposing conditions... contribute to (i.e., increases or decreases) the likelihood that one or more threat events... result in adverse impacts... (e.g., the location of a facility in a hurricane- or flood-prone region... or a stand-alone information system)", NIST SP 800-30 Rev.1, σελ. 10

[122]: "Organizations can eliminate certain threat events from further consideration if no adversary with the necessary capability has been identified. Organizations can also modify the threat events provided", NIST SP 800-30 Rev.1, σελ. E-1

[123]: "Managing risk is a complex, multifaceted activity that requires the involvement of the entire organization from senior leaders/executives... to individuals on the front lines", NIST SP 800-39, σελ. 6

[124]: "The risk executive (function) requires a mix of skills, expertise, and perspectives... supported by an expert staff", NIST SP 800-39, σελ. 13

[125]: "Individuals with information security/risk assessment and monitoring responsibilities (e.g., system evaluators, penetration testers, security control assessors...)", NIST SP 800-30 Rev.1, σελ. 3

[126]: "The risk management process is carried out seamlessly across the three tiers... effective inter-tier and intra-tier communication", NIST SP 800-39, σελ. 9

[127]: "Where automated monitoring is feasible, it should be employed because it is generally faster, more efficient, and more cost-effective than manual monitoring.", NIST SP 800-39, σελ. 47

[128]: "This publication is intended to serve a diverse group... Individuals with oversight responsibilities... (e.g., heads of agencies, chief executive officers...)", NIST SP 800-39, σελ. 3

[129]: "The risk executive (function) serves as the common risk management resource for senior leaders/executives... authorizing officials... security control assessors", NIST SP 800-39, σελ. 12

[130]: "Appendix K provides the essential elements of information that organizations can use to communicate the results of risk assessments... (i) an executive summary; (ii) the main body... and (iii) supporting appendices.", NIST SP 800-30 Rev.1, σελ. K-1

[131]: "The fourth component of risk management addresses how organizations monitor risk over time... verify that planned risk response measures are implemented... determine the ongoing effectiveness", NIST SP 800-39, σελ. 7

[132]: "Where automated monitoring is feasible, it should be employed because it is generally faster, more efficient, and more cost-effective than manual monitoring.", NIST SP 800-39, σελ. 47

Εργαλεία

[133]: SimpleRisk Pricing & Licensing Model | SimpleRisk

<https://www.simplerisk.com/pricing>

- [134]: Manual Installation Download Form | SimpleRisk
<https://www.simplerisk.com/download/manual>
- [135]: Try SimpleRisk: Demo, Trial & Sandbox Options | SimpleRisk
<https://www.simplerisk.com/try>
- [136]: What are the requirements for me to run SimpleRisk? | SimpleRisk Support
<https://simplerisk.freshdesk.com/support/solutions/articles/6000156747-what-are-the-requirements-for-me-to-run-simplerisk->
- [137]: SimpleRisk Sandbox Environment (Screenshots: Self Assessments Menu) | SimpleRisk Demo <https://demo.simplerisk.com>
- [138]: Details about the ISMS-Tool verinice.
<https://verinice.com/en/products/verinice/about-verinice>
- [139]: Software. <https://shop.verinice.com/en/Software/>
- [140]: verinice Standalone for information security management.
<https://verinice.com/en/products/verinice/verinice-standalone>
- [141]: verinice. (2020) verinice Demo: Establishing an ISMS according to ISO 27001.
https://www.youtube.com/watch?v=vB-xLN_vZnY
- [142] EAR - Environment for the Analysis of Risk. <https://www.pilar-tools.com/en/>
- [143] CCN-CERT, "PILAR - What is PILAR?". <https://pilar.ccn-cert.cni.es/en/pilar-solution/what-is-pilar>
- [144] PILAR Basic - User's Manual (2025), Chapter I: Introduction
- [145] PILAR Basic - User's Manual (2025), Chapter II: Novice user (II.1. Essential assets)
- [146] PILAR Basic - User's Manual (2025), Chapter II: Novice user (II.2. Support assets / II.3. Automation)
- [147] PILAR Basic - User's Manual (2025), Chapter II: Novice user (II.1.2. Rating)
- [148] PILAR Basic - User's Manual (2025), Chapter II: Novice user (II.4. Security profiles)
- [149] PILAR Basic - User's Manual (2025), Chapter II: Novice user (II.3. Automation) & Chapter IV: Advanced user (IV.1. Threats)
- [150] PILAR Basic - User's Manual (2025), Chapter II: Novice user (II.3. Automation)
- [151] PILAR Basic - User's Manual (2025), Chapter II: Novice user (II.4.3. Rating)
- [152] PILAR Basic - User's Manual (2025), Chapter II: Novice user (II.4.4 Traffic light)
- [153] PILAR Basic - User's Manual (2025), Chapter II: Novice user (II.5. Reporting)

- [154] MONARC Project, "Documentation & Project Identity".
<https://www.monarc.lu/documentation/>
- [155] MONARC Project, "Quick Start Guide». <https://www.monarc.lu/documentation/quick-start/>
- [156] MONARC Project, "Technical Guide (Architecture & Requirements)".
<https://www.monarc.lu/documentation/technical-guide/>
- [157] MONARC Documentation - User Guide, "Risk Analysis: Asset Definition & Tree Structure". <https://www.monarc.lu/documentation/user-guide/>
- [158] MONARC Documentation - Method Guide, "Libraries & Objects Management".
<https://www.monarc.lu/documentation/method-guide/>
- [159] MONARC Documentation - Method Guide, "Risk Calculation & Assessment Scale". <https://www.monarc.lu/documentation/method-guide/>
- [160] MONARC Documentation - User Guide, "Reporting & Exports (SoA, Risk Treatment)". <https://www.monarc.lu/documentation/user-guide/>
- [161] MONARC Documentation - User Guide, "Dashboard & Interface Overview".
<https://www.monarc.lu/documentation/user-guide/>
- [162] MONARC Documentation - Method Guide, "Context Modelling & Inheritance".
<https://www.monarc.lu/documentation/method-guide/>
- [163] MONARC Project, "Features & Usability (Optimised Method)".
<https://www.monarc.lu/product/>